

Security Review — Checkmarx False-Positive Responses

Managed package **Pledgivo** (namespace `pledgivo`) · responses prepared 2026-09-28 against source commit `75a4dabe`

1. Scan

Scanner	Force.com Source Scanner (Checkmarx)
Scan Id	a0OKX000001JRxU2AW
Engine / preset	CxEngine 9.7 / PortalAll
Job type	ZIP_UPLOAD
Scan start / end	2026-09-16 02:29:10 / 2026-09-16 08:09:05
Security issues reported	474 paths, 108 distinct code locations
Quality issues	0

2. How to read this document

Checkmarx reports one *path* per source-to-sink dataflow, so a single line of code is often reported many times (one path per entry point that reaches it). Section 4 answers each **code location** once, with a response ID (**R-*nnn***). The **Location** column lists the query and the path numbers exactly as they appear in the scan report, the file and line at scan time, and the file and line in the submitted source. Where one location is flagged by more than one query, its full response appears under the first query and later queries refer back to it. Appendix A lists all 474 paths individually with their source, sink and response ID.

Recurring platform facts the responses rely on:

- **Explicit user mode.** Queries and DML the scanner flags as missing `USER_MODE` often pass `AccessLevel.USER_MODE` as a method argument (the FFLib selector pattern); the query does not read that argument.
- **Deliberate system mode.** The `SYSTEM_MODE` / `as system` operations reported here fall into these families: (a) the Experience Cloud guest licence cannot hold the grant; (b) the object is the detail side of a master-detail relationship, where field permissions are inert and a user-mode query throws, so access is checked on the master; (c) asynchronous or install context (batch, queueable, platform-event subscriber, install handler) with no interactive user; (d) a standard object a second-generation package permission set cannot grant; (e) administrator-only setup-console operations on the package's own configuration and on setup objects such as permission-set assignments.
- **Sharing.** Every top-level class declares a sharing keyword. `without sharing` is used for scheduled/batch/queueable jobs, guest controllers, narrow inner wrappers and logging infrastructure, and each top-level declaration states its reason in the code. The package is built at API 67.0, where a class with no keyword runs `with sharing`, or in its parent class's mode when it extends one.
- **Email sends.** Every `Messaging.sendEmail` the scan reports sets `setSaveAsActivity(false)`, so the send creates no activity record, and its recipient is read from the donation record (the donor, or the tribute honoree the donor named at checkout), never from a request parameter.

3. Summary by query

Query	Paths	False positive	Fixed since scan	Hardening before submission	Confirmed — fix
Apex CRUD Violation	34	34	0	0	0
Apex CRUD ContentDistribution	7	7	0	0	0
Client DOM Stored XSS	1	1	0	0	0
CRUD Delete	2	2	0	0	0
FLS Create	201	201	0	0	0
FLS Update	158	158	0	0	0
JS Stored XSS	4	0	4	0	0
Apex SOQL SOSL USER MODE MISSING	34	34	0	0	0
Sharing	31	31	0	0	0
Apex VF Dynamic JS Resource	2	2	0	0	0
Total	474	470	4	0	0

Query descriptions (from the scan report)

Apex CRUD Violation	This query looks for CRUD operations that are performed without checking for isAccessible(), isUpdateable() or isDeletable(). When an object uses Whold, WhatId, ParentId, LinkedEntityId fields an additional CRUD check should also be performed on the parent object along with the CRUD and FLS checks on the child object and fields.
Apex CRUD ContentDistribution	USER_MODE is recommended for DML operations involving "ContentDistribution" object
Client DOM Stored XSS	This query detects external data flowing into a javascript execution context when that data comes from the database or other stored parameters influenced by external users. This may be a false positive if the datatype is safe to render unescaped (such as an integer or rich text field).
CRUD Delete	This query looks for CRUD Delete operations that are performed without checking for isDeletable() permission before performing the delete operation.
FLS Create	This query looks for CRUD Delete operations that are performed without checking for isCreatable() permission before performing the Create operation on the Object and its fields.
FLS Update	This query looks for CRUD Update operations that are performed without checking for isUpdateable() permission before performing the Update operation on the Object and its fields.

JS Stored XSS	Avoid dynamically loading third-party JavaScript files from content delivery networks (CDNs). Instead, load the code from the static resources folder of your package.
Apex SOQL SOSL USER MODE MISSING	USER_MODE is recommended for SOQL or SOSL operations
Sharing	All entry points to an app (Global or Controller classes) must use the 'with sharing' keyword. Classes without this keyword run without sharing if they are entry points to your code, or with the sharing policy of the caller. Do not omit the sharing declaration as this hides critical security information in side-effects that can change when code is refactored. Only declare classes as 'without sharing' if they are not entry points to your app and if they only modify objects whose security is managed by your code (such as wizard state, or fields in a site). It is a common misconception to believe that batch apex or async apex must run with the global keyword. This is not true, the only classes that must be global are those that expose webservices or are intended to be used by extension packages. All async apex should run as public in order to avoid creating privileged entry points to your app.
Apex VF Dynamic JS Resource	Static resources must be used load third-party javascript code

4. Responses

Apex CRUD Violation — 34 paths, 13 locations

Reported vulnerability	Location	Response
R-001 Apex CRUD Violation False positive	Paths 1, 9, 15 At scan: classes/PaymentSetupGuideService.cls:1753 Submitted source: classes/payment/service/PaymentSetupGuideService.cls:1753	The flagged line is a regular-expression match on a string already in memory; it is not a query or DML statement. The data it examines was read with WITH USER_MODE, so the running administrator's object and field permissions were already enforced, and only credential and parameter names are retained for a setup checklist. The path is reachable only by the administrator permission set; the fake-Id generator source is test-only and the other is the SOQL builder. - PaymentSetupGuideService.cls:1753 Matcher m = MERGE_FORMULA.matcher(...); if (m.find()) - queryNamedCredentials (~:1462) and queryCustomHeaders (~:1482) WITH USER_MODE - SetupController.cls:226; SetupController granted only in Fundraising_Admin - fflib_ApexMocks.mock/verify and fflib_IDGenerator.generate are vendored test-support framework code: they are only ever invoked from *_Test classes to build stubs and fake Ids, and no production entry point reaches this sink through them. - fflib_QueryFactory.setCondition/selectField(s)/addOrdering is the SOQL builder the selectors use; it is a query-construction helper, not an entry point, and appears as a source only because the engine starts the trace at the builder's string parameters.

Reported vulnerability	Location	Response
R-002 Apex CRUD Violation False positive	Paths 2, 14 At scan: classes/ReceiptService.cls:501 Submitted source: classes/donation/service/ReceiptService.cls:501	The tribute notice is a one-time email to the honoree address the donor entered with their gift, sent during server-side finalization on first creation and only when the donor opted in. It has no target record (setTargetObjectId(null)) and setSaveAsActivity(false), so it writes nothing. The reported sources are a test-only fake-Id generator and the SOQL builder. - ReceiptService.cls:582-584 setTargetObjectId(null), setToAddresses(honoree), setSaveAsActivity(false) - DonationService.cls:345 caller - fflib_ApexMocks.mock/verify and fflib_IDGenerator.generate are vendored test-support framework code: they are only ever invoked from *_Test classes to build stubs and fake Ids, and no production entry point reaches this sink through them. - fflib_QueryFactory.setCondition/selectField(s)/addOrdering is the SOQL builder the selectors use; it is a query-construction helper, not an entry point, and appears as a source only because the engine starts the trace at the builder's string parameters.
R-003 Apex CRUD Violation False positive	Paths 3, 19 At scan: classes/ReceiptService.cls:49 Submitted source: classes/donation/service/ReceiptService.cls:49	This sink sends a template receipt to the donor Contact of the gift that was just finalized; setTargetObjectId and setWhatId select the recipient and the merge-field sources, and setSaveAsActivity(false) is set, so the send writes no Task/activity record and performs no DML the user could be denied. The recipient is derived from the Opportunity, never from caller input. The only interactive reach is a staff retry of a stuck donation (a permission-set-granted console action), which re-runs the same scheduled finalization and sends the receipt only on first creation of the gift. The QueryFactory 'source' is the SOQL builder, not an entry point. - ReceiptService.cls:43-49 — setTemplateId, setTargetObjectId(targetContactId), setWhatId(opportunityId), setSaveAsActivity(false), applySender, sendEmail - DonationService.cls:340 — sendDonationReceipt called on first creation only - DonationMonitorController.cls:32 retryDonationStagingNow -> StagingReconciliationBatch.reconcileOne (without sharing) - OpportunitiesSelector.selectDonorContactById (lines ~245-253) SYSTEM_MODE with reason comment - fflib_QueryFactory.setCondition/selectField(s)/addOrdering is the SOQL builder the selectors use; it is a query-construction helper, not an entry point, and appears as a source only because the engine starts the trace at the builder's string parameters.

Reported vulnerability	Location	Response
R-004 Apex CRUD Violation False positive	Paths 4, 17, 27 At scan: classes/RefundRequestHandler.cls:124 Submitted source: classes/guestrequest/handler/RefundRequestHandler.cls:124	This notifies staff that a donor asked for a refund through the donor portal; the gift Id was checked against the authenticated donor's own giving history when the request was recorded, and the message goes to that gift's owner and the configured reply-to address, never to a caller-supplied address. It is plain text with explicit addresses and setSaveAsActivity(false), so it writes no record. The reported sources are the SOQL builder's parameter methods, not entry points. - RefundRequestHandler.cls:180-185 setToAddresses + setSaveAsActivity(false) - DonorPortalService.submitRefundRequest -> requireOwnedDonation - fflib_QueryFactory.setCondition/selectField(s)/addOrdering is the SOQL builder the selectors use; it is a query-construction helper, not an entry point, and appears as a source only because the engine starts the trace at the builder's string parameters.
R-005 Apex CRUD Violation False positive	Paths 5, 29-30 At scan: classes/ReceiptService.cls:614 Submitted source: classes/donation/service/ReceiptService.cls:614	Recurring-gift notices (confirmation, failed payment, dunning, re-authorization) are sent by the finalize path and a scheduled renewal job to the schedule's own donor Contact, with setSaveAsActivity(false), so the send writes no record. No user- or guest-callable entry point reaches this method. The reported sources are the SOQL builder's parameter methods. - ReceiptService.cls:589-614 - RecurringRenewalBatch.cls:145-150; RecurringDonationService.cls:602 - fflib_QueryFactory.setCondition/selectField(s)/addOrdering is the SOQL builder the selectors use; it is a query-construction helper, not an entry point, and appears as a source only because the engine starts the trace at the builder's string parameters.
R-006 Apex CRUD Violation False positive	Paths 6, 28, 31 At scan: classes/ReceiptService.cls:111 Submitted source: classes/donation/service/ReceiptService.cls:111	Resending a receipt is a staff action whose record access is enforced before the message is built: the gift and the donor Contact are read in user mode (object, field and sharing checks of the running user), so a user who cannot see either gets nothing to send. The recipient is always the gift's own donor Contact, not a caller-supplied address, and setSaveAsActivity(false) means the send writes no record. The other two sources reported are the SOQL builder's parameters, not entry points. - ReceiptService.cls:134 oppSel.selectById (USER_MODE), :149 conSel.selectById (USER_MODE) - ReceiptService.cls:161-165 setTargetObjectId + setSaveAsActivity(false) - ReceiptAdminController.cls:26 resendReceipt, class declared with sharing - Fundraising_User / Fundraising_Admin permission sets grant ReceiptAdminController - fflib_QueryFactory.setCondition/selectField(s)/addOrdering is the SOQL builder the selectors use; it is a query-construction helper, not an entry point, and appears as a source only because the engine starts the trace at the builder's string parameters.

Reported vulnerability	Location	Response
R-007 Apex CRUD Violation False positive	Paths 7 At scan: classes/ReceiptService.cls:91 Submitted source: classes/donation/service/ReceiptService.cls:91	The event-ticket receipt is sent to the purchaser's own Contact after the purchase is finalized; setSaveAsActivity(false) means the send creates no activity record, so there is no create/read/update/delete for a CRUD check to guard. The recipient Id comes from the purchase record, not from any request parameter. The only reported source is the SOQL builder class, which is a helper rather than an entry point. - ReceiptService.cls:85-91 — setTargetObjectId, setWhatId, setSaveAsActivity(false), sendEmail - EventPurchaseService.cls:601 caller - fflib_QueryFactory.setCondition/selectField(s)/addOrdering is the SOQL builder the selectors use; it is a query-construction helper, not an entry point, and appears as a source only because the engine starts the trace at the builder's string parameters.
R-008 Apex CRUD Violation False positive	Paths 8, 10, 18, 26 At scan: classes/ReceiptService.cls:420 Submitted source: classes/donation/service/ReceiptService.cls:420	This is an internal alert sent by a scheduled reconciliation job to the owner of a disputed gift and the configured reply-to address; it uses explicit addresses, no target record, and setSaveAsActivity(false), so it performs no DML. No user- or guest-reachable code path reaches it; the reported sources are a test-only fake-Id generator and the SOQL builder's parameter methods. - ReceiptService.cls:476-481 setToAddresses + setSaveAsActivity(false) - RefundReconciliationBatch.cls:457 sole caller - OpportunitiesSelector.selectOwnerEmailById :685 SYSTEM_MODE - fflib_ApexMocks.mock/verify and fflib_IDGenerator.generate are vendored test-support framework code: they are only ever invoked from *_Test classes to build stubs and fake Ids, and no production entry point reaches this sink through them. - fflib_QueryFactory.setCondition/selectField(s)/addOrdering is the SOQL builder the selectors use; it is a query-construction helper, not an entry point, and appears as a source only because the engine starts the trace at the builder's string parameters.
R-009 Apex CRUD Violation False positive	Paths 11, 21, 33 At scan: classes/ReceiptService.cls:264 Submitted source: classes/donation/service/ReceiptService.cls:264	Every source reported for this sink is test-support framework code (the mocking library's mock/verify methods and its fake-Id generator), which is only called from test classes. In production the method runs from a platform-event subscriber after a gift is finalized and emails matching-gift instructions to that gift's own donor Contact. setSaveAsActivity(false) is set, so no activity record is written and there is no DML to check. - ReceiptService.cls:248-262 — loop builds messages, setSaveAsActivity(false) - CompanyMatchService.cls:59 sole production caller - fflib_ApexMocks.mock/verify and fflib_IDGenerator.generate are vendored test-support framework code: they are only ever invoked from *_Test classes to build stubs and fake Ids, and no production entry point reaches this sink through them.

Reported vulnerability	Location	Response
R-010 Apex CRUD Violation False positive	Paths 12, 22, 24 At scan: classes/DonorPortalService.cls:411 Submitted source: classes/donor/service/DonorPortalService.cls:411	This sends a one-time sign-in code to a donor's own address after a guest asks for it; the address must match an existing donor, the request is rate-limited, and the response is the same whether or not it matched. The message uses explicit addresses with no target record and setSaveAsActivity(false), so no record is created. The staff controller methods listed as sources reach a different send site (the staff twin) and share only the message-building helper; the fake-Id generator source is test-only. • DonorPortalService.cls:409-418 sendCodeEmail • buildCodeEmail: setToAddresses, setSaveAsActivity(false) • fflib_ApexMocks.mock/verify and fflib_IDGenerator.generate are vendored test-support framework code: they are only ever invoked from *_Test classes to build stubs and fake Ids, and no production entry point reaches this sink through them.
R-011 Apex CRUD Violation False positive	Paths 13, 23, 25 At scan: classes/DonorPortalService.cls:469 Submitted source: classes/donor/service/DonorPortalService.cls:469	The CRUD finding on the send itself is a false positive: setSaveAsActivity(false) is set and no record is written by Messaging.sendEmail. Tracing it at scan time exposed that the staff 'send portal link' and 'show portal code' actions accepted a Contact Id and resolved its email in system mode without confirming the running user could see that Contact. That was fixed before submission: both staff twins now re-read the donor in the staff user's own mode (resolveStaffDonorEmail, USER_MODE selectors for Contact and Person Account) and refuse a donor that user cannot see, before any code is minted, any email is sent or any address is returned. The guest path, which is authorized by possession of the code it produces, is unchanged. • HEAD DonorPortalService.cls:30-47 - class header: the staff twins re-read the donor in the STAFF user's mode (resolveStaffDonorEmail) and refuse a donor that user cannot see • HEAD DonorPortalAdminController.cls:57 SendPortalLinkAction, :78 CreatePortalLinkAction, :141 ContactsSelector.selectById (USER_MODE), :160 AccountsSelector.selectPersonDonorById (USER_MODE) • DonorPortalService_Test / DonorPortalAdminController_Test: a Fundraising_User who cannot see the Contact gets 'not found' and no Portal_Access_Token__c row is created • docs/security/appexchange-security-review-readiness.md F-10 (donor-portal IDOR closed 2026-09-25)

Reported vulnerability	Location	Response
R-012 Apex CRUD Violation False positive	Paths 16 At scan: classes/CommunityService.cls:458 Submitted source: classes/setup/service/CommunityService.cls:458	This is a read-only count of the site guest user's permission-set assignments, run from the administrator-only setup console to report whether the payment credential is granted to that guest user; it returns a yes/no verdict and no record data. It runs in system mode because PermissionSetAssignment is setup data that the running administrator can read only with 'View Setup and Configuration', which the package's admin permission set does not grant, and without it the console would falsely report the grant as missing. Only users holding the administrator permission set can reach it. Since the scan the site carries its own SYSTEM_MODE comment saying so, as does every other setup-object read in the class. • HEAD CommunityService.cls:489-494 - // SYSTEM_MODE: the guest user's assignments ... a count only, for the Fundraising_Admin-only Settings console. above the query • python3 scripts/lint/system-mode-inventory.py -> 0 unjustified sites (header-only count now excludes this file's reads) • SetupController granted only in Fundraising_Admin; Fundraising_Admin carries no ViewSetup userPermission
R-013 Apex CRUD Violation False positive	Paths 20, 32, 34 At scan: classes/ReceiptService.cls:335 Submitted source: classes/donation/service/ReceiptService.cls:335	The refund notice is sent only after a refund has been processed, to the refunded gift's own donor Contact, with setSaveAsActivity(false), so the send itself writes no record. The interactive path requires a dedicated custom permission checked in the controller before any work, and the controller declares with sharing, which the service inherits. Two of the reported sources are test-only mocking framework methods; the third is that permission-gated controller. • RefundController.cls:10 refundDonation; doValidate checks FeatureManagement.checkPermission('Process_Refunds') • RefundService (inherited sharing) :195 sendRefundNotifications after commit • ReceiptService.cls:327-335 setSaveAsActivity(false) • OpportunitiesSelector.selectByIdForRefund :638 SYSTEM_MODE FOR UPDATE • fflib_ApexMocks.mock/verify and fflib_IDGenerator.generate are vendored test-support framework code: they are only ever invoked from *_Test classes to build stubs and fake Ids, and no production entry point reaches this sink through them.

Apex CRUD ContentDistribution — 7 paths, 5 locations

Reported vulnerability	Location	Response
R-014 Apex CRUD ContentDistribution False positive	Paths 1, 4 At scan: classes/CampaignPostService.cls:392 Submitted source: classes/campaign/service/CampaignPostService.cls:392	At scan time this call created the public download link for a campaign 'Document' post's file with <code>insert as system</code>, justified by ContentDistribution being a standard object a 2GP permission set cannot grant. Since the scan the public link is the one write in this class that is NOT system mode: ContentDistribution is inserted with Database.insert(..., AccessLevel.USER_MODE), so the platform's own 'Create Public Links' permission and object CRUD decide whether the running user may publish a file; a failed row simply gets no URL and the reason is logged. A link is minted only for a Document-type post the running user can edit (RecordAccess.editableIds) whose parent Campaign the user can see (CampaignsSelector.selectIdsVisibleToUser), and never from a guest context. The flagged <code>as system</code> statement no longer exists at this site. • HEAD CampaignPostService.cls:23-25 - header: the public link is inserted in USER_MODE so 'Create Public Links' decides • HEAD CampaignPostService.cls:624-625 - <code>// USER_MODE: minting a public link is the uploader's act</code> then Database.insert(toCreate, false, AccessLevel.USER_MODE) • HEAD CampaignPostService.cls:328 RecordAccess.editableIds(postIds); :344 CampaignsSelector.selectIdsVisibleToUser(campaignIds); :347 Document-type filter • docs-site/docs/guides/campaign-posts.md 'Who can publish a file'; docs/security/appexchange-security-review-readiness.md F-10
R-015 Apex CRUD ContentDistribution False positive	Paths 2 At scan: classes/TestDataFactory.cls:430 Submitted source: classes/shared/TestDataFactory.cls:430	TestDataFactory is an @IsTest class; seedOrgLogoOnSettings builds fixture data (a sample ContentDistribution and a Settings__c row) for unit tests and cannot be invoked from production code. System mode is used so fixtures can be created regardless of the runAs user under test. • base/main/default/classes/shared/TestDataFactory.cls:1-4 - @IsTest, <code>without sharing</code> with rationale • base/main/default/classes/shared/TestDataFactory.cls:416-437 - seedOrgLogoOnSettings fixture
R-016 Apex CRUD ContentDistribution False positive	Paths 3 At scan: classes/TestDataFactory.cls:436 Submitted source: classes/shared/TestDataFactory.cls:436	TestDataFactory is an @IsTest class; seedOrgLogoOnSettings builds fixture data (a sample ContentDistribution and a Settings__c row) for unit tests and cannot be invoked from production code. System mode is used so fixtures can be created regardless of the runAs user under test. • base/main/default/classes/shared/TestDataFactory.cls:1-4 - @IsTest, <code>without sharing</code> with rationale • base/main/default/classes/shared/TestDataFactory.cls:416-437 - seedOrgLogoOnSettings fixture

Reported vulnerability	Location	Response
R-017 Apex CRUD ContentDistribution False positive	Paths 5–6 At scan: classes/SettingsService.cls:73 Submitted source: classes/setup/service/SettingsService.cls:73	This upsert is shared by the package install handler, which runs as the package's system user with no permission set, and by the settings console controller, which is granted only in the Fundraising_Admin permission set. System mode is kept because the install path has no FLS to enforce and because DML on a Hierarchy Custom Setting in user mode requires Customize Application, a system permission no packaged permission set can carry. Since the scan, the console path no longer relies on Apex class access alone: every controller action that reaches this write (SaveGeneralSettings, DetectOrgFeatures, ResetToDefaults, SaveExperienceSite) first checks the packaged custom permission Manage_Fundraising_Settings, granted only in Fundraising_Admin, and refuses the save with a generic error when the running user does not hold it. The site now carries a SYSTEM_MODE comment naming that gate. • HEAD SettingsService.cls:74-81 - <code>// SYSTEM_MODE:</code> reason naming the Manage_Fundraising_Settings gate, then <code>upsert as system settings</code> • HEAD SetupController.cls:1401-1406 - <code>SettingsWriteAction.requireSettingsPermission(): FeatureManagement.checkPermission('Manage_Fundraising_Settings') else addError(SETTINGS_NOT_AUTHORIZED)</code> • HEAD SetupController.cls:1409/1418 <code>SaveGeneralSettings, :2270-2271 DetectOrgFeatures, :2306-2307 ResetToDefaults, :2366/2375 SaveExperienceSite</code> - each <code>doValidate()</code> starts with <code>requireSettingsPermission()</code> • <code>base/main/default/customPermissions/Manage_Fundraising_Settings.customPermission-meta.xml; Fundraising_Admin.permissionset-meta.xml</code> grants it; <code>Fundraising_User / Fundraising_ReadOnly / Fundraising_GuestDonor</code> do not • <code>SetupController_Test</code>: five deny tests (bare Standard User), one deny test (<code>Fundraising_User</code>), one allow test (<code>Fundraising_Admin</code>); 312 tests pass, <code>SetupController</code> 96%, <code>SettingsService</code> 98% • <code>PostInstallHandler.onInstall -> seedRecordTypeMappings / ensureDefaultLogoSeeded</code> still reach this write with no permission check: install context, no running user to check • <code>docs/security/appexchange-security-review-readiness.md</code> F-13
R-018 Apex CRUD ContentDistribution False positive	Paths 7 At scan: classes/EventTicketAdminController_Test.cls:484 Submitted source: classes/event/controller/EventTicketAdminController_Test.cls:484	This line is inside an <code>@IsTest</code> class and runs only during Apex test execution; it deletes a fixture record to simulate a stale Id. The reported dataflow source (a <code>ContentDistribution</code> query in <code>SettingsService</code>) has no connection to this statement - the scanner linked unrelated nodes. No production code path reaches it. • <code>base/main/default/classes/event/controller/EventTicketAdminController_Test.cls</code> - <code>@IsTest</code> class; line 484 test fixture delete • <code>base/main/default/classes/setup/service/SettingsService.cls:346</code> - the cited source is an unrelated <code>ContentDistribution</code> re-read

Client DOM Stored XSS — 1 paths, 1 locations

Reported vulnerability	Location	Response
R-019 Client DOM Stored XSS False positive	Paths 1 At scan: lwc/pfGivingStatement/pfGivingStatement.html:34 Submitted source: lwc/pfGivingStatement/pfGivingStatement.html:34	The flagged source is the donor's own portal session token read from sessionStorage; it is passed as an Apex parameter to DonorPortalController.getGivingStatement and is never written into the DOM. The value rendered at pfGivingStatement.html:34 is either the <code>error</code> string of the controller's response envelope or a package-authored literal. The controller's action classes extend GuestAction, whose callerSafeMessage returns an AppException message (every one on this path is a constant: the invalid-session message, 'Choose a tax year.', 'That tax year is not available.', 'A donor is required to build a giving statement.') or one fixed generic sentence for any other exception - no record field, request parameter or token is echoed. Finally, the sink is an LWC <code>{expression}</code> text binding, which the framework renders as a text node, not HTML; neither pfGivingStatement nor publicDonorDashboard uses innerHTML, lwc:inner-html or lwc:dom="manual". - base/main/default/lwc/publicDonorDashboard/publicDonorDashboard.js:305-313 - stored = sessionStorage.getItem('pf-donor-portal-session'); assigned to this.token then loadDashboard(); not bound into markup - base/main/default/lwc/publicDonorDashboard/publicDonorDashboard.html:365 - token={token} passed as a component property only; the only other {token} use is if:false={token} (line 45), a boolean - base/main/default/lwc/pfGivingStatement/pfGivingStatement.js:96-104 and :115-121 - errorMessage = res?.error literal, or the printStatement() return value - base/main/default/lwc/uiStatementPrint/uiStatementPrint.js:249 - printStatement returns only the literal 'Pop-up blocked. Allow pop-ups ...' or null; the statement document itself is built with createElement/textContent (el) helper :31-35), never innerHTML - base/main/default/classes/donor/controller/DonorPortalController.cls:69-71, :235-245, :318-324 - getGivingStatement -> TokenAction.doValidate requireNotBlank('token is required') -> validateToken -> service - base/main/default/classes/shared/GuestAction.cls:36-38 - callerSafeMessage returns AppException message verbatim, otherwise GENERIC_FAILURE constant - base/main/default/classes/shared/ControllerAction.cls:40-52 - validation errors joined from addError literals; exceptions routed through callerSafeMessage; full message to AppLogger only - base/main/default/classes/donor/service/DonorPortalService.cls:51-52, :582-597 - validateToken throws AppException(INVALID_MSG) constant for every failure - base/main/default/classes/donation/service/GivingStatementService.cls:268, :273, :280-282 - the only AppExceptions on the statement path are constant strings - grep lwc:dom lwc:inner-html innerHTML in lwc/pfGivingStatement and lwc/publicDonorDashboard - zero hits

CRUD Delete — 2 paths, 2 locations

Reported vulnerability	Location	Response
R-020 CRUD Delete False positive	Paths 1 At scan: classes/fplib_SObjectUnitOfWork.cls:217 Submitted source: classes/fplib/fplib_SObjectUnitOfWork.cls:217	This is the user-mode delete in the FFLib Unit of Work's UserModeDML strategy; the access level passed is AccessLevel.USER_MODE by default, so the platform itself enforces the running user's delete permission, sharing and FLS. The scanner cannot see an isDeletable() call because enforcement is done by the Database method's access-level argument. No subscriber code path uses this class outside its own test. - base/main/default/classes/fplib/fplib_SObjectUnitOfWork.cls:192-217 - UserModeDML extends SimpleDML with m_accessLevel = USER_MODE - grep: UserModeDML referenced only in fplib_SObjectUnitOfWorkTest
R-021 CRUD Delete False positive	Paths 2 At scan: classes/RetentionPurgeBatch.cls:66 Submitted source: classes/shared/async/RetentionPurgeBatch.cls:66	This is the data-retention purge: the scope is produced only by the per-target selector locators (Log__c and Transaction_Log__c older than the admin-configured retention window, terminal Donation_Staging__c and Guest_Request__c older than it, and terminal or stale portal tokens after 7 days). It runs as a scheduled batch or when an administrator runs it from the setup console; no caller supplies record Ids. No packaged permission set grants Delete on these append-only tables by design, so the purge must delete in system mode. - base/main/default/classes/shared/async/RetentionPurgeBatch.cls:1-9 - rationale; without sharing - base/main/default/classes/shared/async/RetentionPurgeBatch.cls:25-62 - fixed selector locators per Target; else throws - base/main/default/classes/setup/service/SettingsService.cls:584-589 - dataRetentionDays default 90 (no lower floor; admin-controlled)

FLS Create — 201 paths, 23 locations

Reported vulnerability	Location	Response
R-022 FLS Create False positive	Paths 1 At scan: classes/ReconciliationHeartbeat.cls:23 Submitted source: classes/donation/async/ReconciliationHeartbeat.cls:23	This is an operations alarm written by a scheduled job with no user input: every field is a constant or a message built from a count of stuck staging rows. The job is scheduled at package install (post-install context, which holds no permission sets) or by an administrator from the setup console, so the insert must not depend on the scheduling user's Transaction_Log__c grants; Transaction_Log__c is an internal audit object not granted to guests. No record Id or value from a caller reaches the insert. - base/main/default/classes/donation/async/ReconciliationHeartbeat.cls:8-10 - without sharing with rationale (claims Automated Process) - base/main/default/classes/donation/async/ReconciliationHeartbeat.cls:15-25 - execute(): selector count -> constant-valued log insert -> admin email - base/main/default/classes/setup/controller/PostInstallHandler.cls - scheduleIfAbsent schedules it in install context

Reported vulnerability	Location	Response
R-023 FLS Create False positive	Paths 2–7 At scan: <code>classes/AppLogger.cls:77</code> Submitted source: <code>classes/shared/AppLogger.cls:77</code>	AppLogger persists diagnostic entries from catch blocks in every context, including guest controllers whose users cannot hold Create on any internal object; no permission set grants Create on Log__c by design, so logs are writable only through this class. Values are truncated to field length, Log__c is Private with read granted only to internal staff sets, and no client-callable method takes a log payload - the message text comes from server-side exceptions and developer-written strings. The class-level comment documents why it is without sharing and bypasses the Unit of Work. - base/main/default/classes/shared/AppLogger.cls:1-4 - without sharing with rationale - base/main/default/classes/shared/AppLogger.cls:72-87 - DML-limit guard; left() truncation; failures swallowed - Log__c OWD Private; Fundraising_Admin/User/ReadOnly: Read only, no Create; GuestDonor: no grant
R-024 FLS Create False positive	Paths 8–12 At scan: <code>classes/StripePaymentSweep.cls:163</code> Submitted source: <code>classes/donation/async/StripePaymentSweep.cls:163</code>	logSweep records the outcome of the scheduled Stripe-to-Salesforce repair sweep; its arguments are constants chosen by the sweep, the staging Id it is repairing, and a caught exception message. The sweep is scheduled at install or started by an administrator from the setup console, and the install-context owner holds no permission sets, so the audit insert runs in system mode. No caller-supplied value reaches it. - base/main/default/classes/donation/async/StripePaymentSweep.cls:23-25 - without sharing with rationale - base/main/default/classes/donation/async/StripePaymentSweep.cls:162-170 - private logSweep, all values from sweep internals
R-017 FLS Create False positive	Paths 13, 46, 70–74, 81–159, 161–165, 167–168, 170, 176, 178 At scan: <code>classes/SettingsService.cls:73</code> Submitted source: <code>classes/setup/service/SettingsService.cls:73</code>	See R-017 under “Apex CRUD ContentDistribution” — same code location, same response.

Reported vulnerability	Location	Response
R-025 FLS Create False positive	Paths 14–36, 47–50 At scan: classes/PostInstallHandler.cls:170 Submitted source: classes/setup/controller/PostInstallHandler.cls:170	This seeds the org-default row of the package's hierarchy custom setting with constant defaults during package install or upgrade, filling only blank fields. It runs only from the InstallHandler, which executes as the package's special system user; that user holds no permission set, so there is no user FLS to enforce. The method is not reachable from any controller, guest page or subscriber Apex. - base/main/default/classes/setup/controller/PostInstallHandler.cls:9 public without sharing class PostInstallHandler implements InstallHandler; lines 1-2 header: 'runs in package install/upgrade context' - base/main/default/classes/setup/controller/PostInstallHandler.cls:66-70 doc: 'the script runs as a per-package system user that does not exist before runtime' - Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet) - base/main/default/classes/setup/controller/PostInstallHandler.cls:76-87 onInstall calls each seed* step in its own try/catch; only logStepFailure on error - grep of non-test classes: seedDefaultSettings, seedDefaultImages, seedDefaultPageDesign, seedEventPricebook, seedEventDonationProduct, seedEventFeeProduct, seedContentTemplates have NO callers outside PostInstallHandler (mentions in PricebookService/SettingsService are comments/strings only) - Class is public, not global (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods - base/main/default/classes/setup/controller/PostInstallHandler.cls:~105-170 seedDefaultSettings: creates the org-default Settings__c only if absent (SetupOwnerId = org Id) and backfills blank colour/text defaults from constants; adoptTributeMasterSwitch reads Campaign WITH SYSTEM_MODE - All values are package constants or derived from existing org data; no user input
R-026 FLS Create False positive	Paths 37–38, 51, 63, 75–76 At scan: classes/StagingReconciliationBatch.cls:239 Submitted source: classes/donation/async/StagingReconciliationBatch.cls:239	This inserts the reconciliation audit row (Transaction_Log__c) for each staging the job processes; every field is system-derived (staging Id, Opportunity Id created by the same transaction, a constant event type/status, an exception message, a timestamp). It runs in the scheduled reconciler and the internal retry action; the scheduled run can be owned by the install context user, which holds no permission sets, so the audit write must not depend on the running user's grants. Transaction_Log__c is internal and not granted to the guest profile. - base/main/default/classes/donation/async/StagingReconciliationBatch.cls:160-212 - log fields populated from staging Id, oppld, constants, e.getMessage() - base/main/default/classes/donation/async/StagingReconciliationBatch.cls:239 - single insert per staging

Reported vulnerability	Location	Response
R-027 FLS Create False positive	Paths 39–40 At scan: classes/RefundReconciliationBatch.cls:532 Submitted source: classes/donation/async/RefundReconciliationBatch.cls:532	This write stores two Datetime high-water marks (refund and dispute cursors) computed by the batch from the payment gateway's list responses; no user-supplied value reaches it. It runs only in the scheduled reconciliation job or when an administrator starts that job from the settings console, and the cursor must advance regardless of the scheduling user's field permissions or the next run re-reads the whole window. Enforcing FLS here would not protect any user data; it would only let a missing grant silently stall reconciliation. - base/main/default/classes/donation/async/RefundReconciliationBatch.cls:526-537 finish(): only when !hadError; sets Refund_Reconcile_Cursor__c / Dispute_Reconcile_Cursor__c from cursorTarget/disputeCursorTarget (system-computed), then <code>upsert as system s</code> - base/main/default/classes/donation/async/RefundReconciliationBatch.cls:133-139 reads the same cursors with a 2h overlap - Scheduled Apex executes in the context of the user who scheduled it (CronTrigger owner), in system mode - not the Automated Process user - Fundraising_Admin holds edit on both cursor fields; the only interactive trigger (runJobNow) is Fundraising_Admin-only - base/main/default/classes/donation/async/RefundReconciliationBatch.cls:528 uses Settings__c.getInstance() and falls back to getOrgDefaults() only when Id is null - if the running user has a user- or profile-level Settings__c row, the cursor is written to that row, not the org default (SettingsService header rule: always getOrgDefaults())
R-028 FLS Create False positive	Paths 41–42, 65 At scan: classes/SettingsService.cls:676 Submitted source: classes/setup/service/SettingsService.cls:676	This writes one of two scheduling-interval fields on the org-default Settings__c row; the family is checked against two fixed names and the interval against a fixed allow-list before the write. It is reached only from the settings console controller's ScheduleJobFamily action, which is granted only in the Fundraising_Admin permission set. System mode is retained because DML on a Hierarchy Custom Setting in user mode requires Customize Application, which a packaged permission set cannot grant. Since the scan, ScheduleJobFamily.doValidate() first checks the packaged custom permission Manage_Fundraising_Settings (granted only in Fundraising_Admin) and refuses the save when the running user does not hold it; the site carries a SYSTEM_MODE comment naming that gate. - HEAD SettingsService.cls:684-688 - <code>// SYSTEM_MODE:</code> reason naming the ScheduleJobFamily gate, then <code>upsert as system s</code> - HEAD SetupController.cls:1812-1821 - ScheduleJobFamily extends SettingsWriteAction; doValidate() calls requireSettingsPermission() before the family / interval checks - SetupController_Test.test_scheduleJobFamily_userWithoutSettingsPermission_isRefused - Fundraising_Admin is the only permission set with SetupController classAccess and the only one carrying Manage_Fundraising_Settings - docs/security/appexchange-security-review-readiness.md F-13

Reported vulnerability	Location	Response
R-029 FLS Create False positive	Paths 43, 66 At scan: classes/PostInstallHandler.cls:1488 Submitted source: classes/setup/controller/PostInstallHandler.cls:1488	This stores the Id of the event pricebook that the same install step just found or created on the org-default custom setting row, only when that field is blank. It runs only from the InstallHandler as the package's system user, which has no permission set to enforce, and never overwrites an administrator's value. No user input reaches the write. - base/main/default/classes/setup/controller/PostInstallHandler.cls:9 public without sharing class PostInstallHandler implements InstallHandler; lines 1-2 header: 'runs in package install/upgrade context' - base/main/default/classes/setup/controller/PostInstallHandler.cls:66-70 doc: 'the script runs as a per-package system user that does not exist before runtime' - Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet) - base/main/default/classes/setup/controller/PostInstallHandler.cls:76-87 onInstall calls each seed* step in its own try/catch; only logStepFailure on error - grep of non-test classes: seedDefaultSettings, seedDefaultImages, seedDefaultPageDesign, seedEventPricebook, seedEventDonationProduct, seedEventFeeProduct, seedContentTemplates have NO callers outside PostInstallHandler (mentions in PricebookService/SettingsService are comments/strings only) - Class is public, not global (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods - Only backfills when the field is blank ('only backfills the Settings lookup when blank, so an admin's own configuration is never overwritten on upgrade' - method Javadoc) - Value is the Id of a record this same method just found or inserted; no user input

Reported vulnerability	Location	Response
R-030 FLS Create False positive	Paths 44, 67 At scan: classes/PostInstallHandler.cls:1526 Submitted source: classes/setup/controller/PostInstallHandler.cls:1526	This records the Id of the event donation product, found or created by the same install step, on the org-default custom setting row when that field is blank. It runs only from the InstallHandler as the package's system user and does not overwrite an administrator's value. No user input reaches the write. - base/main/default/classes/setup/controller/PostInstallHandler.cls:9 public without sharing class PostInstallHandler implements InstallHandler; lines 1-2 header: 'runs in package install/upgrade context' - base/main/default/classes/setup/controller/PostInstallHandler.cls:66-70 doc: 'the script runs as a per-package system user that does not exist before runtime' - Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet) - base/main/default/classes/setup/controller/PostInstallHandler.cls:76-87 onInstall calls each seed* step in its own try/catch; only logStepFailure on error - grep of non-test classes: seedDefaultSettings, seedDefaultImages, seedDefaultPageDesign, seedEventPricebook, seedEventDonationProduct, seedEventFeeProduct, seedContentTemplates have NO callers outside PostInstallHandler (mentions in PricebookService/SettingsService are comments/strings only) - Class is public, not global (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods - Only backfills when the field is blank ('only backfills the Settings lookup when blank, so an admin's own configuration is never overwritten on upgrade' - method Javadoc) - Value is the Id of a record this same method just found or inserted; no user input

Reported vulnerability	Location	Response
R-031 FLS Create False positive	Paths 45, 68 At scan: classes/PostInstallHandler.cls:1566 Submitted source: classes/setup/controller/PostInstallHandler.cls:1566	This records the Id of the event processing-fee product, found or created by the same install step, on the org-default custom setting row when that field is blank. It runs only from the InstallHandler as the package's system user and never overwrites an administrator's value. No user-supplied data reaches it. - base/main/default/classes/setup/controller/PostInstallHandler.cls:9 public without sharing class PostInstallHandler implements InstallHandler; lines 1-2 header: 'runs in package install/upgrade context' - base/main/default/classes/setup/controller/PostInstallHandler.cls:66-70 doc: 'the script runs as a per-package system user that does not exist before runtime' - Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet) - base/main/default/classes/setup/controller/PostInstallHandler.cls:76-87 onInstall calls each seed* step in its own try/catch; only logStepFailure on error - grep of non-test classes: seedDefaultSettings, seedDefaultImages, seedDefaultPageDesign, seedEventPricebook, seedEventDonationProduct, seedEventFeeProduct, seedContentTemplates have NO callers outside PostInstallHandler (mentions in PricebookService/SettingsService are comments/strings only) - Class is public, not global (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods - Only backfills when the field is blank ('only backfills the Settings lookup when blank, so an admin's own configuration is never overwritten on upgrade' - method Javadoc) - Value is the Id of a record this same method just found or inserted; no user input
R-032 FLS Create False positive	Paths 52–54 At scan: classes/SettingsService.cls:279 Submitted source: classes/setup/service/SettingsService.cls:279	PackagedAssetSeeder copies the package's own static-resource images (default logo, hero image, social-share image) into ContentVersion so the public pages have a default; Title/PathOnClient are constants and VersionData is the packaged resource body. It runs in the post-install context, whose user holds no permission sets, and ContentVersion is a standard object a second-generation package permission set cannot grant. The interactive admin upload of a custom logo uses user mode instead. - base/main/default/classes/setup/service/SettingsService.cls:~265-300 - PackagedAssetSeeder, inner without sharing with rationale; content from DefaultOrgLogo/DefaultHeroImage/DefaultSocialShareImage - base/main/default/classes/setup/service/SettingsService.cls createLogoDistribution - USER_MODE for the admin upload path
R-033 FLS Create False positive	Paths 55–59 At scan: classes/SettingsService.cls:297 Submitted source: classes/setup/service/SettingsService.cls:297	This publishes a public link for the package's own default image, which must be publicly reachable because it is rendered on unauthenticated donation pages and in receipt emails. The file is created one line earlier from a packaged static resource, so no subscriber or user file can be published through this path. It runs in the post-install context (no permission sets) or from an administrator's reset-to-default action. base/main/default/classes/setup/service/SettingsService.cls:286-297 - ContentDistribution on the ContentVersion just inserted from a static resource

Reported vulnerability	Location	Response
R-034 FLS Create False positive	Paths 60 At scan: classes/PostInstallHandler.cls:1478 Submitted source: classes/setup/controller/PostInstallHandler.cls:1478	This creates the package's event pricebook once, at install, with a constant name, only if it does not already exist. Pricebook2 is a standard object that a packaged permission set cannot grant, and the method runs only from the InstallHandler as the package's system user. No controller, guest page or subscriber code can call it. - base/main/default/classes/setup/controller/PostInstallHandler.cls:9 public without sharing class PostInstallHandler implements InstallHandler; lines 1-2 header: 'runs in package install/upgrade context' - base/main/default/classes/setup/controller/PostInstallHandler.cls:66-70 doc: 'the script runs as a per-package system user that does not exist before runtime' - Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet) - base/main/default/classes/setup/controller/PostInstallHandler.cls:76-87 onInstall calls each seed* step in its own try/catch; only logStepFailure on error - grep of non-test classes: seedDefaultSettings, seedDefaultImages, seedDefaultPageDesign, seedEventPricebook, seedEventDonationProduct, seedEventFeeProduct, seedContentTemplates have NO callers outside PostInstallHandler (mentions in PricebookService/SettingsService are comments/strings only) - Class is public, not global (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods - Pricebook2 and Product2 are standard objects; AGENTS.md / readiness FP-1 item 2 record that a 2GP permission set cannot ship a standard-object grant (build strips it silently), and the install user holds no permission set anyway - PricebookService.cls:11-24 doc: install-testing (2026-08-09) showed a with sharing path could not even resolve Pricebook2 as the per-package system user - base/main/default/classes/setup/controller/PostInstallHandler.cls:1477 new Pricebook2(Name = EVENT_PRICEBOOK_NAME, IsActive = true) - constant values; inserted only when neither the current nor the legacy pricebook exists

Reported vulnerability	Location	Response
R-035 FLS Create False positive	Paths 61 At scan: classes/PostInstallHandler.cls:1508 Submitted source: classes/setup/controller/PostInstallHandler.cls:1508	This creates the package's generic event donation product once, at install, with constant field values and only if it does not already exist. Product2 is a standard object that a packaged permission set cannot grant, and the code runs only from the InstallHandler as the package's system user. It is not reachable from any user-facing entry point. - base/main/default/classes/setup/controller/PostInstallHandler.cls:9 public without sharing class PostInstallHandler implements InstallHandler; lines 1-2 header: 'runs in package install/upgrade context' - base/main/default/classes/setup/controller/PostInstallHandler.cls:66-70 doc: 'the script runs as a per-package system user that does not exist before runtime' - Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet) - base/main/default/classes/setup/controller/PostInstallHandler.cls:76-87 onInstall calls each seed* step in its own try/catch; only logStepFailure on error - grep of non-test classes: seedDefaultSettings, seedDefaultImages, seedDefaultPageDesign, seedEventPricebook, seedEventDonationProduct, seedEventFeeProduct, seedContentTemplates have NO callers outside PostInstallHandler (mentions in PricebookService/SettingsService are comments/strings only) - Class is public, not global (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods - Pricebook2 and Product2 are standard objects; AGENTS.md / readiness FP-1 item 2 record that a 2GP permission set cannot ship a standard-object grant (build strips it silently), and the install user holds no permission set anyway - PricebookService.cls:11-24 doc: install-testing (2026-08-09) showed a with sharing path could not even resolve Pricebook2 as the per-package system user - base/main/default/classes/setup/controller/PostInstallHandler.cls:1507 new Product2(Name = EVENT_DONATION_PRODUCT_NAME, IsActive = true) - constants; only when no Product2 with that name exists (query WITH SYSTEM_MODE)

Reported vulnerability	Location	Response
R-036 FLS Create False positive	Paths 62 At scan: classes/PostInstallHandler.cls:1548 Submitted source: classes/setup/controller/PostInstallHandler.cls:1548	This creates the package's event processing-fee product once, at install, with constant values and only if it does not already exist. Product2 is a standard object a packaged permission set cannot grant, and the method runs only from the InstallHandler as the package's system user. It has no interactive or guest caller. - base/main/default/classes/setup/controller/PostInstallHandler.cls:9 public without sharing class PostInstallHandler implements InstallHandler; lines 1-2 header: 'runs in package install/upgrade context' - base/main/default/classes/setup/controller/PostInstallHandler.cls:66-70 doc: 'the script runs as a per-package system user that does not exist before runtime' - Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet) - base/main/default/classes/setup/controller/PostInstallHandler.cls:76-87 onInstall calls each seed* step in its own try/catch; only logStepFailure on error - grep of non-test classes: seedDefaultSettings, seedDefaultImages, seedDefaultPageDesign, seedEventPricebook, seedEventDonationProduct, seedEventFeeProduct, seedContentTemplates have NO callers outside PostInstallHandler (mentions in PricebookService/SettingsService are comments/strings only) - Class is public, not global (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods - Pricebook2 and Product2 are standard objects; AGENTS.md / readiness FP-1 item 2 record that a 2GP permission set cannot ship a standard-object grant (build strips it silently), and the install user holds no permission set anyway - PricebookService.cls:11-24 doc: install-testing (2026-08-09) showed a with sharing path could not even resolve Pricebook2 as the per-package system user - base/main/default/classes/setup/controller/PostInstallHandler.cls:1547 new Product2(Name = EVENT_FEE_PRODUCT_NAME, IsActive = true) - constants; only when absent
R-037 FLS Create False positive	Paths 64 At scan: classes/EventPurchaseService.cls:659 Submitted source: classes/event/service/EventPurchaseService.cls:659	After a paid ticket order is finalized by the reconciliation job, attendees with a Contact are added to the event Campaign as CampaignMembers. CampaignMember is a standard object that a second-generation package permission set cannot grant, and the finalizer runs in scheduled context, so the insert runs in system mode. The Campaign comes from the server-side staging record and the Contacts from the attendees created in the same finalization; existing members are skipped, and no browser input chooses either. - base/main/default/classes/event/service/EventPurchaseService.cls:640-659 - campaign from staging, contacts from attendees, existing members excluded - Comment cites 'CampaignMemberSyncService.syncForOpportunities', which does not exist (method is syncForDonations); 'after a guest order is committed' - it actually runs in the batch/retry finalizer

Reported vulnerability	Location	Response
R-038 FLS Create False positive	Paths 69 At scan: classes/CampaignMemberSyncService.cls:76 Submitted source: classes/donation/service/CampaignMemberSyncService.cls:76	This adds the donor to the donation's campaign as a CampaignMember after a gift is finalized; it runs in the platform-event subscriber trigger, which executes as the Automated Process entity. CampaignMember is a standard object that a second-generation package permission set cannot grant, and the Automated Process context has no user permissions to enforce. CampaignId and ContactId are read from the finalized Opportunity itself, and existing memberships are skipped, so the insert cannot target arbitrary campaigns or contacts. - base/main/default/classes/donation/service/CampaignMemberSyncService.cls:64 - CampaignMember built from Opportunity CampaignId + resolved contact - base/main/default/classes/donation/service/CampaignMemberSyncService.cls:76 - comment present and accurate
R-014 FLS Create False positive	Paths 77–80 At scan: classes/CampaignPostService.cls:392 Submitted source: classes/campaign/service/CampaignPostService.cls:392	See R-014 under “Apex CRUD ContentDistribution” — same code location, same response.

Reported vulnerability	Location	Response
R-039 FLS Create False positive	Paths 160, 180, 182–186 At scan: classes/PostInstallHandler.cls:1608 Submitted source: classes/setup/controller/PostInstallHandler.cls:1608	This inserts a starter set of question and FAQ templates, whose text is literal in the package source, the first time the package is installed and only when the template table is empty. It runs only from the InstallHandler as the package's system user, which holds no permission set. Administrators edit or delete these templates afterwards through the normal, permission-checked console. - base/main/default/classes/setup/controller/PostInstallHandler.cls:9 public without sharing class PostInstallHandler implements InstallHandler; lines 1-2 header: 'runs in package install/upgrade context' - base/main/default/classes/setup/controller/PostInstallHandler.cls:66-70 doc: 'the script runs as a per-package system user that does not exist before runtime' - Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet) - base/main/default/classes/setup/controller/PostInstallHandler.cls:76-87 onInstall calls each seed* step in its own try/catch; only logStepFailure on error - grep of non-test classes: seedDefaultSettings, seedDefaultImages, seedDefaultPageDesign, seedEventPricebook, seedEventDonationProduct, seedEventFeeProduct, seedContentTemplates have NO callers outside PostInstallHandler (mentions in PricebookService/SettingsService are comments/strings only) - Class is public, not global (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods - base/main/default/classes/setup/controller/PostInstallHandler.cls:~1580-1635 seedContentTemplates inserts starter question/FAQ Content_Template__c rows (RecordTypeId, Name, Prompt__c, Question_Type__c, Is_Active__c, Picklist_Options__c, Answer__c) only when the table is empty; all text is literal in source

Reported vulnerability	Location	Response
R-040 FLS Create False positive	Paths 166, 169, 175, 177, 179, 181, 187–201 At scan: classes/PostInstallHandler.cls:663 Submitted source: classes/setup/controller/PostInstallHandler.cls:663	This creates or refreshes the six packaged page-design theme records from constants compiled into the package, during install or upgrade. It runs only from the InstallHandler as the package's system user, which holds no permission set, and every assigned value is a literal from the package source. Packaged themes are read-only to administrators, who clone them to customise, so no administrator data is overwritten. - base/main/default/classes/setup/controller/PostInstallHandler.cls:9 public without sharing class PostInstallHandler implements InstallHandler; lines 1-2 header: 'runs in package install/upgrade context' - base/main/default/classes/setup/controller/PostInstallHandler.cls:66-70 doc: 'the script runs as a per-package system user that does not exist before runtime' - Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet) - base/main/default/classes/setup/controller/PostInstallHandler.cls:76-87 onInstall calls each seed* step in its own try/catch; only logStepFailure on error - grep of non-test classes: seedDefaultSettings, seedDefaultImages, seedDefaultPageDesign, seedEventPricebook, seedEventDonationProduct, seedEventFeeProduct, seedContentTemplates have NO callers outside PostInstallHandler (mentions in PricebookService/SettingsService are comments/strings only) - Class is public, not global (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods - base/main/default/classes/setup/controller/PostInstallHandler.cls:~600-663 seedDefaultPageDesign upserts the six packaged Campaign_Design__c theme rows; buildTheme (:1167+) assigns colours, fonts, radius, widths from compile-time theme constants; reads WITH SYSTEM_MODE; followed by retireDeletedDesigns - Packaged themes are read-only in the console (clone to edit), so overwriting their style fields on upgrade is the intended contract
R-041 FLS Create False positive	Paths 171, 173 At scan: classes/PricebookService.cls:83 Submitted source: classes/event/service/PricebookService.cls:83	This creates the standard pricebook PricebookEntry a ticket Product2 needs before an OpportunityLineItem can reference it. Values are fixed by Apex (the Product2 the package created for the ticket tier, the pricebook Id, a placeholder unit price, IsActive=true, the org currency) - the real price lives on the line item. PricebookEntry/Pricebook2 are standard objects the package permission sets cannot grant, and the same method runs in the post-install context and the scheduled finalizer; the staff entry point first verifies the user can see the event Campaign and that the tier belongs to it. - base/main/default/classes/event/service/PricebookService.cls - class without sharing with doc rationale (Pricebook2 unresolvable under with sharing in post-install context) - base/main/default/classes/event/service/PricebookService.cls:129-130 - PricebookEntry(Product2Id, Pricebook2Id, UnitPrice=PLACEHOLDER_PRICE, IsActive=true) - base/main/default/classes/event/controller/EventTicketAdminController.cls:131-148, 169-232 - requireCampaignVisible + requireTiersBelongToCampaign before ensureEntriesFor; wrapped non-fatal

Reported vulnerability	Location	Response
R-042 FLS Create False positive	Paths 172, 174 At scan: classes/PricebookService.cls:92 Submitted source: classes/event/service/PricebookService.cls:92	This creates the package event pricebook PricebookEntry a ticket Product2 needs before an OpportunityLineItem can reference it. Values are fixed by Apex (the Product2 the package created for the ticket tier, the pricebook Id, a placeholder unit price, IsActive=true, the org currency) - the real price lives on the line item. PricebookEntry/Pricebook2 are standard objects the package permission sets cannot grant, and the same method runs in the post-install context and the scheduled finalizer; the staff entry point first verifies the user can see the event Campaign and that the tier belongs to it. - base/main/default/classes/event/service/PricebookService.cls - class without sharing with doc rationale (Pricebook2 unresolvable under with sharing in post-install context) - base/main/default/classes/event/service/PricebookService.cls:129-130 - PricebookEntry(Product2Id, Pricebook2Id, UnitPrice=PLACEHOLDER_PRICE, IsActive=true) - base/main/default/classes/event/controller/EventTicketAdminController.cls:131-148, 169-232 - requireCampaignVisible + requireTiersBelongToCampaign before ensureEntriesFor; wrapped non-fatal

FLS Update — 158 paths, 15 locations

Reported vulnerability	Location	Response
R-017 FLS Update False positive	Paths 1, 35–122, 126–127, 131, 134, 137, 140 At scan: classes/SettingsService.cls:73 Submitted source: classes/setup/service/SettingsService.cls:73	See R-017 under “Apex CRUD ContentDistribution” — same code location, same response.
R-025 FLS Update False positive	Paths 2–24 At scan: classes/PostInstallHandler.cls:170 Submitted source: classes/setup/controller/PostInstallHandler.cls:170	See R-025 under “FLS Create” — same code location, same response.

Reported vulnerability	Location	Response
R-043 FLS Update False positive	Paths 25 At scan: classes/StagingReconciliationBatch.cls:236 Submitted source: classes/donation/async/StagingReconciliationBatch.cls:236	The reconciler writes the finalization error and, for an unpaid staging past its TTL, sets Status__c='Expired'; the values come from the caught exception and Stripe's PaymentIntent status, never from the caller. It runs in a scheduled batch and in an internal 'retry now' action; Fundraising_User can view and retry stagings but deliberately has no Edit on Donation_Staging__c (the row is system-owned state), so the status transition must run in system mode. The only caller input is the staging Id on the retry path, and the action it triggers is the same idempotent reconciliation the scheduler would perform anyway. - base/main/default/classes/donation/async/StagingReconciliationBatch.cls:222-237 - upd built from e.getMessage() and pi.status; Expired only when past TTL and payment not succeeded - base/main/default/permissionsets/Fundraising_User - Donation_Staging__c Create/Read, no Edit - base/main/default/classes/donation/staging/DonationStagingSelector.cls selectById - SYSTEM_MODE read, so retry has no record-visibility gate (minor; controller granted only to staff sets)
R-044 FLS Update False positive	Paths 26 At scan: classes/DonorPortalService.cls:311 Submitted source: classes/donor/service/DonorPortalService.cls:311	This increments the failed-attempt counter on a donor-portal access code and locks it after the maximum attempts - a brute-force defence. The guest user cannot hold Edit on any object, and the credential table carries no guest grant at all, so the write must be system mode. The row is resolved server-side from the submitted email under FOR UPDATE, never from a client-supplied Id, and the only fields written are Attempt_Count__c and Status__c='Locked', both computed by Apex. The worst a caller can do is lock a code, which the legitimate donor replaces by requesting a new one. - base/main/default/classes/donor/service/DonorPortalService.cls:295-311 - bump built from selector row; attempts computed server-side - base/main/default/classes/donor/service/DonorPortalService.cls class header - without sharing with rationale - Portal_Access_Token__c has no Fundraising_GuestDonor grant (permset doc comment) - ControllerAction.run has no savepoint rollback on caught error, so the increment persists after a failed verify (intended)
R-027 FLS Update False positive	Paths 27-28 At scan: classes/RefundReconciliationBatch.cls:532 Submitted source: classes/donation/async/RefundReconciliationBatch.cls:532	See R-027 under “FLS Create” — same code location, same response.

Reported vulnerability	Location	Response
R-028 FLS Update False positive	Paths 29–30 At scan: classes/SettingsService.cls:676 Submitted source: classes/setup/service/SettingsService.cls:676	See R-028 under “FLS Create” — same code location, same response.
R-045 FLS Update False positive	Paths 31 At scan: classes/PostInstallHandler.cls:1474 Submitted source: classes/setup/controller/PostInstallHandler.cls:1474	This renames the package's own event pricebook from its earlier name to the current one during upgrade, so existing price book entries are kept. Pricebook2 is a standard object that a packaged permission set cannot grant, and the code runs only from the InstallHandler as the package's system user. The new name is a constant; nothing user-supplied is written. - base/main/default/classes/setup/controller/PostInstallHandler.cls:9 public without sharing class PostInstallHandler implements InstallHandler; lines 1-2 header: 'runs in package install/upgrade context' - base/main/default/classes/setup/controller/PostInstallHandler.cls:66-70 doc: 'the script runs as a per-package system user that does not exist before runtime' - Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet) - base/main/default/classes/setup/controller/PostInstallHandler.cls:76-87 onInstall calls each seed* step in its own try/catch; only logStepFailure on error - grep of non-test classes: seedDefaultSettings, seedDefaultImages, seedDefaultPageDesign, seedEventPricebook, seedEventDonationProduct, seedEventFeeProduct, seedContentTemplates have NO callers outside PostInstallHandler (mentions in PricebookService/SettingsService are comments/strings only) - Class is public, not global (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods - Pricebook2 and Product2 are standard objects; AGENTS.md / readiness FP-1 item 2 record that a 2GP permission set cannot ship a standard-object grant (build strips it silently), and the install user holds no permission set anyway - PricebookService.cls:11-24 doc: install-testing (2026-08-09) showed a with sharing path could not even resolve Pricebook2 as the per-package system user - base/main/default/classes/setup/controller/PostInstallHandler.cls:1455-1475 seedEventPricebook: if only the pre-rename pricebook exists, renames it in place to EVENT_PRICEBOOK_NAME ('Fundraising Events') so its PricebookEntry rows survive; the new name is a constant

Reported vulnerability	Location	Response
R-029 FLS Update False positive	Paths 32 At scan: classes/PostInstallHandler.cls:1488 Submitted source: classes/setup/controller/PostInstallHandler.cls:1488	See R-029 under “FLS Create” — same code location, same response.
R-030 FLS Update False positive	Paths 33 At scan: classes/PostInstallHandler.cls:1526 Submitted source: classes/setup/controller/PostInstallHandler.cls:1526	See R-030 under “FLS Create” — same code location, same response.
R-031 FLS Update False positive	Paths 34 At scan: classes/PostInstallHandler.cls:1566 Submitted source: classes/setup/controller/PostInstallHandler.cls:1566	See R-031 under “FLS Create” — same code location, same response.
R-046 FLS Update False positive	Paths 123–124, 132 At scan: classes/AttendeeNamingHandler.cls:91 Submitted source: classes/guestrequest/handler/AttendeeNamingHandler.cls:91	A donor who is signed in to the donor portal with a verified access code may name the blank guest seats on their own ticket order. Ownership is checked synchronously before anything is queued (requireOwnedOrder against the portal session), the verified order Id is stored server-side in Subject_Id__c, and this handler re-reads the seats of that order only - seat Ids in the payload that are not on the order, cancelled seats, and seats already named are ignored. The only fields written are First_Name__c, Last_Name__c and (when blank) Email__c, length-clipped and email-validated, which are exactly the data the donor is entitled to supply; the Guest licence cannot hold Edit, hence system mode. - base/main/default/classes/donor/service/DonorPortalService.cls:1063-1115 - requireOwnedOrder(ctx, orderId); payload rebuilt from owned seats, never echoed from the browser - base/main/default/classes/guestrequest/handler/AttendeeNamingHandler.cls:45-79 - seats re-read from Subject_Id__c order; unmatched/cancelled/already-named seats skipped; NAME_MAX/EMAIL_MAX - base/main/default/classes/guestrequest/handler/AttendeeNamingHandler.cls:10-14 - without sharing with rationale - base/main/default/classes/guestrequest/handler/AttendeeNamingHandler.cls:19 - MAX_SEATS payload cap

Reported vulnerability	Location	Response
R-047 FLS Update False positive	Paths 125, 133 At scan: classes/GuestRequestService.cls:117 Submitted source: classes/guestrequest/service/GuestRequestService.cls:117	This claims queued public requests (Status__c Pending -> Processing, Attempt_Count__c + 1) so the queueable and the sweep never process the same row twice. It runs in the guest user's own queueable - the Guest licence cannot hold Edit on any object - or in the scheduled sweep; the request Ids come from the row the server just inserted or from the sweep's query, and only rows still Pending are claimed. Both written values are computed by Apex. - base/main/default/classes/guestrequest/service/GuestRequestService.cls:102-117 - only Pending rows; status/attempts computed - base/main/default/classes/guestrequest/async/GuestRequestQueueable.cls:17, GuestRequestSweepBatch.cls:30 - sole callers of process() - Fundraising_GuestDonor has no Edit on Guest_Request__c
R-048 FLS Update False positive	Paths 128, 135, 138 At scan: classes/GuestRequestService.cls:196 Submitted source: classes/guestrequest/service/GuestRequestService.cls:196	After staff refund a gift, this closes the donor's matching refund request that was parked for review so the donor portal stops showing it as pending. It runs only after the refund itself succeeded under the refund controller's own authorization, it selects requests by the refunded Opportunity Id and only those in Awaiting_Review of the refund type, and it writes a fixed status, a fixed donor-facing sentence and a timestamp. The request rows are created by the guest user and owned by the site's default owner, so an internal user generally has no sharing on them; system mode is what lets the refund close its own request. - base/main/default/classes/donation/service/RefundService.cls:207-212 - sole caller, constant status/message - base/main/default/classes/guestrequest/service/GuestRequestService.cls:173-197 - filters to Awaiting_Review + type - Fundraising_User has Edit but not View All on Guest_Request__c; Admin has Modify All - so the real blocker for a user-mode update is record sharing, not the object grant

Reported vulnerability	Location	Response
R-049 FLS Update False positive	Paths 129 At scan: classes/PostInstallHandler.cls:314 Submitted source: classes/setup/controller/PostInstallHandler.cls:314	This backfills the default hero image URL on the package's own theme records during install or upgrade, limited to the packaged theme names. It runs only from the InstallHandler as the package's system user, which has no permission set, and the value is a URL the install step itself generated from a packaged static resource. No interactive or guest caller reaches it. - base/main/default/classes/setup/controller/PostInstallHandler.cls:9 public without sharing class PostInstallHandler implements InstallHandler; lines 1-2 header: 'runs in package install/upgrade context' - base/main/default/classes/setup/controller/PostInstallHandler.cls:66-70 doc: 'the script runs as a per-package system user that does not exist before runtime' - Salesforce: a post-install script 'runs as a special system user that represents your package' (search-result excerpt of the help page; page body itself not fetchable, so the quote is from the indexed snippet) - base/main/default/classes/setup/controller/PostInstallHandler.cls:76-87 onInstall calls each seed* step in its own try/catch; only logStepFailure on error - grep of non-test classes: seedDefaultSettings, seedDefaultImages, seedDefaultPageDesign, seedEventPricebook, seedEventDonationProduct, seedEventFeeProduct, seedContentTemplates have NO callers outside PostInstallHandler (mentions in PricebookService/SettingsService are comments/strings only) - Class is public, not global (changed 2026-09-05), so subscriber anonymous Apex / other namespaces cannot invoke these methods - base/main/default/classes/setup/controller/PostInstallHandler.cls:~290-314 seedDefaultImages: copies the seeded default hero image URL from Settings__c onto Campaign_Design__c.Default_Hero_Image_URL__c for the packaged theme names only, and only when changed; the query is WITH SYSTEM_MODE - Value originates from the packaged static-resource distribution URL seeded by SettingsService.ensureDefaultImagesSeeded, not user input
R-040 FLS Update False positive	Paths 130, 136, 139, 141–158 At scan: classes/PostInstallHandler.cls:663 Submitted source: classes/setup/controller/PostInstallHandler.cls:663	See R-040 under “FLS Create” — same code location, same response.

JS Stored XSS — 4 paths, 4 locations

Reported vulnerability	Location	Response
R-050 JS Stored XSS Fixed since scan	Paths 1 At scan:  Submitted source: <i>code removed</i>	This finding no longer exists in the submitted source. At scan time the flagged code appended a <link rel=stylesheet> whose href was the constant <code>\${PUBLIC_FONTS}/fonts.css</code>, where PUBLIC_FONTS is <code>@salesforce/resourceUrl/PublicFonts</code> - a packaged, same-org static resource containing only @font-face rules with relative woff2 URLs; no user, admin or remote value reached the element. The hand-built element has since been replaced by <code>loadStyle(this, \${PUBLIC_FONTS}/fonts.css)</code> from <code>lightning/platformResourceLoader</code>, the documented path for loading a static-resource stylesheet from an LWC, and no <code>document.createElement('link')</code> remains anywhere in the package. - base/main/default/lwc/publicCampaignGallery/publicCampaignGallery.js:123 (<code>_ensureBrandFont</code>) - HEAD calls <code>loadStyle(this, \${PUBLIC_FONTS}/fonts.css)</code> inside a once-per-instance guard - base/main/default/lwc/publicCampaignGallery/publicCampaignGallery.js - imports PUBLIC_FONTS from '@salesforce/resourceUrl/PublicFonts' and loadStyle from 'lightning/platformResourceLoader' - grep -rn "createElement('link')" base/ at HEAD - only two hits, both in comments (publicFundraisingExperience.js:372, publicCampaignGallery.js:54); zero code occurrences - git show 9af07169 - removed lines show the old href was the constant <code>\${PUBLIC_FONTS}/fonts.css</code>, never a remote host or variable input - base/main/default/staticresources/PublicFonts/fonts.css - only @font-face rules with <code>src:url('./fonts/*.woff2')</code>; no http(s) URL or @import - base/main/default/staticresources/PublicFonts.resource-meta.xml - application/zip, cacheControl Public, self-hosted OFL/Apache fonts

Reported vulnerability	Location	Response
R-051 JS Stored XSS Fixed since scan	Paths 2 At scan:  Submitted source: <i>code removed</i>	This finding no longer exists in the submitted source. At scan time the flagged code appended a <link rel=stylesheet> whose href was the constant <code>\${PUBLIC_FONTS}/fonts.css</code>, where PUBLIC_FONTS is <code>@salesforce/resourceUrl/PublicFonts</code> - a packaged, same-org static resource containing only @font-face rules with relative woff2 URLs; no user, admin or remote value reached the element. The hand-built element has since been replaced by <code>loadStyle(this, \${PUBLIC_FONTS}/fonts.css)</code> from <code>lightning/platformResourceLoader</code>, the documented path for loading a static-resource stylesheet from an LWC, and no <code>document.createElement('link')</code> remains anywhere in the package. - base/main/default/lwc/publicDonorDashboard/publicDonorDashboard.js:438 (<code>_ensureBrandFont</code>) - HEAD calls <code>loadStyle(this, \${PUBLIC_FONTS}/fonts.css)</code> inside a once-per-instance guard - base/main/default/lwc/publicDonorDashboard/publicDonorDashboard.js - imports PUBLIC_FONTS from '@salesforce/resourceUrl/PublicFonts' and loadStyle from 'lightning/platformResourceLoader' - grep -rn "createElement('link')" base/ at HEAD - only two hits, both in comments (publicFundraisingExperience.js:372, publicCampaignGallery.js:54); zero code occurrences - git show 9af07169 - removed lines show the old href was the constant <code>\${PUBLIC_FONTS}/fonts.css</code>, never a remote host or variable input - base/main/default/staticresources/PublicFonts/fonts.css - only @font-face rules with <code>src:url('./fonts/*.woff2')</code>; no http(s) URL or @import - base/main/default/staticresources/PublicFonts.resource-meta.xml - application/zip, cacheControl Public, self-hosted OFL/Apache fonts

Reported vulnerability	Location	Response
R-052 JS Stored XSS Fixed since scan	Paths 3 At scan:  Submitted source: <i>code removed</i>	This finding no longer exists in the submitted source. At scan time the flagged code appended a <code><link rel=stylesheet></code> whose href was the constant <code>\${PUBLIC_FONTS}/fonts.css</code>, where <code>PUBLIC_FONTS</code> is <code>@salesforce/resourceUrl/PublicFonts</code> - a packaged, same-org static resource containing only <code>@font-face</code> rules with relative woff2 URLs; no user, admin or remote value reached the element. The hand-built element has since been replaced by <code>loadStyle(this, \${PUBLIC_FONTS}/fonts.css)</code> from <code>lightning/platformResourceLoader</code>, the documented path for loading a static-resource stylesheet from an LWC, and no <code>document.createElement('link')</code> remains anywhere in the package. • <code>base/main/default/lwc/publicFundraisingExperience/publicFundraisingExperience.js:383</code> (<code>loadPublicFonts</code>) - HEAD calls <code>loadStyle(this, \${PUBLIC_FONTS}/fonts.css)</code> inside a once-per-instance guard • <code>base/main/default/lwc/publicFundraisingExperience/publicFundraisingExperience.js</code> - imports <code>PUBLIC_FONTS</code> from <code>'@salesforce/resourceUrl/PublicFonts'</code> and <code>loadStyle</code> from <code>'lightning/platformResourceLoader'</code> • <code>grep -rn "createElement('link')" base/</code> at HEAD - only two hits, both in comments (<code>publicFundraisingExperience.js:372</code>, <code>publicCampaignGallery.js:54</code>); zero code occurrences • <code>git show 9af07169</code> - removed lines show the old href was the constant <code>\${PUBLIC_FONTS}/fonts.css</code>, never a remote host or variable input • <code>base/main/default/staticresources/PublicFonts/fonts.css</code> - only <code>@font-face</code> rules with <code>src:url('./fonts/*.woff2')</code>; no <code>http(s)</code> URL or <code>@import</code> • <code>base/main/default/staticresources/PublicFonts.resource-meta.xml</code> - <code>application/zip</code>, <code>cacheControl Public</code>, self-hosted OFL/Apache fonts • <code>git show 9af07169</code> - also deleted <code>syncGoogleFontLink/teardownGoogleFontLink</code> and the <code>googleFontLinkEl</code> field (the old element was removed on disconnect; <code>loadStyle</code> has no <code>unload</code>, which the new comment at :373-374 acknowledges)

Reported vulnerability	Location	Response
R-053 JS Stored XSS Fixed since scan	Paths 4 At scan:  Submitted source: <i>code removed</i>	This finding no longer exists in the submitted source. At scan time the flagged code appended a <link rel=stylesheet> whose href was the constant <code>\${PUBLIC_FONTS}/fonts.css</code>, where PUBLIC_FONTS is <code>@salesforce/resourceUrl/PublicFonts</code> - a packaged, same-org static resource containing only @font-face rules with relative woff2 URLs; no user, admin or remote value reached the element. The hand-built element has since been replaced by <code>loadStyle(this, \${PUBLIC_FONTS}/fonts.css)</code> from <code>lightning/platformResourceLoader</code>, the documented path for loading a static-resource stylesheet from an LWC, and no <code>document.createElement('link')</code> remains anywhere in the package. - base/main/default/lwc/publicThankYou/publicThankYou.js:154 (<code>_ensureBrandFont</code>) - HEAD calls <code>loadStyle(this, \${PUBLIC_FONTS}/fonts.css)</code> inside a once-per-instance guard - base/main/default/lwc/publicThankYou/publicThankYou.js - imports PUBLIC_FONTS from <code>'@salesforce/resourceUrl/PublicFonts'</code> and <code>loadStyle</code> from <code>'lightning/platformResourceLoader'</code> - grep -rn "createElement('link')" base/ at HEAD - only two hits, both in comments (<code>publicFundraisingExperience.js:372</code>, <code>publicCampaignGallery.js:54</code>); zero code occurrences - git show 9af07169 - removed lines show the old href was the constant <code>\${PUBLIC_FONTS}/fonts.css</code>, never a remote host or variable input - base/main/default/staticresources/PublicFonts/fonts.css - only @font-face rules with <code>src:url('./fonts/*.woff2')</code>; no http(s) URL or @import - base/main/default/staticresources/PublicFonts.resource-meta.xml - application/zip, cacheControl Public, self-hosted OFL/Apache fonts

Apex SOQL SOSL USER MODE MISSING — 34 paths, 25 locations

Reported vulnerability	Location	Response
R-054 Apex SOQL SOSL USER MODE MISSING False positive	Paths 1 At scan: <code>classes/PostInstallHandler_Test.cls:1553</code> Submitted source: <code>classes/setup/controller/PostInstallHandler_Test.cls:1553</code>	This is an assertion inside an @IsTest class. It verifies that the post-install handler seeded the Custom_Question content templates. It runs only during Apex test execution with SeeAllData=false, so it can only count rows the test created. There is no runtime caller and no user-supplied input. - base/main/default/classes/setup/controller/PostInstallHandler_Test.cls:1 - class annotated @IsTest(SeeAllData=false) - base/main/default/classes/setup/controller/PostInstallHandler_Test.cls:1550 - the source is <code>Content_Template__c.getRecordTypeInfoByDeveloperName().get('Custom_Question')</code> describe - base/main/default/classes/setup/controller/PostInstallHandler_Test.cls:1553 - an assertion that the post-install seed created Custom_Question templates; the <code>COUNT()</code> only reads rows the test itself caused to be inserted (<code>SeeAllData=false</code>)

Reported vulnerability	Location	Response
R-055 Apex SOQL SOSL USER MODE MISSING False positive	Paths 2 At scan: classes/PostInstallHandler_Test.cls:1555 Submitted source: classes/setup/controller/PostInstallHandler_Test.cls:1555	This is an assertion inside an @IsTest class. It verifies that the post-install handler seeded the FAQ content templates. It runs only during Apex test execution with SeeAllData=false, so it can only count rows the test created. There is no runtime caller and no user-supplied input. - base/main/default/classes/setup/controller/PostInstallHandler_Test.cls:1 - class annotated @IsTest(SeeAllData=false) - base/main/default/classes/setup/controller/PostInstallHandler_Test.cls:1552 - the source is Content_Template__c.getRecordTypeInfoByDeveloperName().get('FAQ') describe - base/main/default/classes/setup/controller/PostInstallHandler_Test.cls:1555 - an assertion that the post-install seed created FAQ templates; the COUNT() only reads rows the test itself caused to be inserted (SeeAllData=false)
R-056 Apex SOQL SOSL USER MODE MISSING False positive	Paths 3 At scan: classes/CurrencyResolver.cls:232 Submitted source: classes/shared/CurrencyResolver.cls:232	The query reads only Id and CurrencyIsoCode for parent records whose Ids the trigger-driven rollup already holds, so it can convert gift amounts into the parent's currency before writing the total. The object name comes from the Id's own schema token, not from input, so the dynamic FROM cannot be injected. The result is a map of Id to ISO code that is used in the arithmetic and never returned to a user. Running in user mode would make a rollup fail or mis-convert for a staff user who can save a gift but lacks read FLS on a standard CurrencyIsoCode field. The code catches any exception and falls back to the corporate currency. - base/main/default/classes/shared/CurrencyResolver.cls:225-236 - dynamic FROM built from Id.getSObjectType().getDescribe().getName(); bind is Set<Id>; SYSTEM_MODE; catch returns empty map - base/main/default/classes/shared/CurrencyResolver.cls - isoCodesByRecordId doc states the reason (currency code is not customer data) - base/main/default/classes/donation/selector/OpportunitiesSelector.cls:135 - upstream SYSTEM_MODE rollup read, itself commented

Reported vulnerability	Location	Response
R-057 Apex SOQL SOSL USER MODE MISSING False positive	Paths 4, 6 At scan: classes/AccountsSelector.cls:211 Submitted source: classes/donor/selector/AccountsSelector.cls:211	This query already runs in user mode: it is executed with Database.queryWithBinds(..., AccessLevel.USER_MODE), which enforces object permissions, field-level security and sharing for the running user. The scanner only recognises the literal WITH USER_MODE clause and does not read the AccessLevel argument. The caller, DonorDetailController.requireDonor, uses this user-mode, sharing-enforced read as its IDOR gate: if the record Id supplied by the component is not visible to the user, zero rows come back and the controller throws "Donor not found" before any related data is read. - base/main/default/classes/donor/selector/AccountsSelector.cls:211--222 - Database.queryWithBinds(..., AccessLevel.USER_MODE); class is inherited sharing - base/main/default/classes/donor/controller/DonorDetailController.cls:313 - requireDonor calls the Account/Contact detail selector and throws QueryException("Donor not found") on an empty result - base/main/default/classes/donor/controller/DonorDetailController.cls:63,142,176,205,238,272 - every @AuraEnabled action calls requireDonor before any other read - base/main/default/classes/donor/controller/DonorDetailController.cls header - documents requireDonor as the gate in front of the SYSTEM_MODE reads of Donation_Designation__c and Guest_Request__c - base/main/default/classes/campaign/controller/FundraiserDetailController.cls:20 - getRecurring never calls AccountsSelector; Checkmarx path 4/6 source is spurious
R-058 Apex SOQL SOSL USER MODE MISSING False positive	Paths 5, 7 At scan: classes/ContactsSelector.cls:178 Submitted source: classes/donor/selector/ContactsSelector.cls:178	The SOQL string is built by the query factory and executed with Database.queryWithBinds(..., AccessLevel.USER_MODE), so object permissions, FLS and sharing are enforced for the running user. The factory is also constructed with CRUD enforcement on. The scanner does not recognise the AccessLevel argument. The only caller that passes a client-supplied Id is DonorDetailController.requireDonor, which throws "Donor not found" when this user-mode read returns nothing, so a user cannot reach another donor's gifts, recurring plans or requests by guessing an Id. - base/main/default/classes/donor/selector/ContactsSelector.cls:178--192 - newQueryFactory() (fflib defaults enforceCRUD=true) then queryWithBinds with AccessLevel.USER_MODE - base/main/default/classes/donor/controller/DonorDetailController.cls:313 - requireDonor gate; empty result -> QueryException - base/main/default/classes/donor/controller/DonorDetailController.cls:63,142,176,205,238,272 - every action gated by requireDonor first - base/main/default/classes/campaign/controller/FundraiserDetailController.cls:20 - getRecurring uses RecurringDonationsSelector.selectByCampaignPaged, not ContactsSelector

Reported vulnerability	Location	Response
R-059 Apex SOQL SOSL USER MODE MISSING False positive	Paths 8, 11 At scan: classes/CommunityService.cls:243 Submitted source: classes/setup/service/CommunityService.cls:243	This read resolves the Experience Cloud site that the administrator is configuring. It returns only the Network's Id, name, URL prefix and status, which are org configuration and not record data. It is reachable only from the package's setup console, whose controller is granted solely by the admin permission set. Network visibility in user mode is limited to sites the user is a member of, unless the user holds Create and Set Up Experiences, View All Data or Modify All Data. The admin must be able to resolve a site they are about to repoint the package at, including one still in Preview. The Id binds as a variable, and the query sits in a try/catch that reports "site not found" instead of exposing an error. - base/main/default/classes/setup/service/CommunityService.cls:243-248 - Database.query with AccessLevel.SYSTEM_MODE; bind variable, not concatenation - base/main/default/classes/setup/service/CommunityService.cls:~225-240 - resolveByNetworkId wraps it in try/catch and logs via AppLogger.info - base/main/default/classes/setup/controller/SetupController.cls:320,325 - saveExperienceSite / checkGuestPermissionSet are @AuraEnabled on a with-sharing controller - base/main/default/permissionsets - only Fundraising_Admin grants classAccess to SetupController; Fundraising_User/ReadOnly deliberately omit it - base/main/default/classes/setup/service/CommunityService.cls:6-8 - public virtual without sharing; header rationale covers Network/User/PSA/BackgroundOperation only https://developer.salesforce.com/docs/atlas.en-us.object_reference.meta/object_reference/sforce_api_objects_network.htm - special access rules: users with Create and Set Up Experiences / View All Data / Modify All Data see all Network rows; others see only sites they are members of
R-017 Apex SOQL SOSL USER MODE MISSING False positive	Paths 9, 18–19, 31 At scan: classes/SettingsService.cls:73 Submitted source: classes/setup/service/SettingsService.cls:73	See R-017 under “Apex CRUD ContentDistribution” — same code location, same response.

Reported vulnerability	Location	Response
R-060 Apex SOQL SOSL USER MODE MISSING False positive	Paths 10 At scan: classes/GuestRequestController_Test.cls:76 Submitted source: classes/guestrequest/controller/GuestRequestController_Test.cls:76	This is a test helper in an @IsTest class. It builds a minimum-access user so the test can assert, under System.runAs, that the controller refuses a caller without the needed permissions. The Profile lookup is fixture setup and is never executed at runtime. The helper exists to test the access controls, not to bypass them. - base/main/default/classes/guestrequest/controller/GuestRequestController_Test.cls:1 - class annotated @IsTest(SeeAllData=false) - base/main/default/classes/guestrequest/controller/GuestRequestController_Test.cls:32 - outsider() fixture queries the 'Minimum Access - Salesforce' Profile Id to build a low-privilege test user - base/main/default/classes/guestrequest/controller/GuestRequestController_Test.cls:76 - returns the inserted test user; used with System.runAs to prove a user without grants is refused
R-061 Apex SOQL SOSL USER MODE MISSING False positive	Paths 12 At scan: classes/CommunityService.cls:275 Submitted source: classes/setup/service/CommunityService.cls:275	This is a read-only diagnostic in the admin setup console. It checks whether the site's guest user has been assigned the package's guest permission set and returns only a boolean and a remediation message. The guest user Id is resolved on the server from the selected site, not taken from the client. No record data is returned, and the read is wrapped in a try/catch that degrades to 'could not verify'. PermissionSetAssignment is a setup object whose visibility is governed by View Setup and Configuration rather than record sharing, which the package's admin permission set does not grant; the read stays in system mode so an administrator without it gets a true answer. Since the scan the site carries its own SYSTEM_MODE comment stating this. - HEAD CommunityService.cls:307-313 - per-site <code>// SYSTEM_MODE:</code> comment directly above the query (setup data about the site GUEST user; only a Boolean / Set<Id> leaves the method) - python3 scripts/lint/system-mode-inventory.py -> 0 unjustified sites - SetupController.cls saveExperienceSite / checkGuestPermissionSet are @AuraEnabled on a with-sharing controller granted only in Fundraising_Admin - docs/security/appexchange-security-review-readiness.md F-1 (third pass, 2026-09-25)
R-012 Apex SOQL SOSL USER MODE MISSING False positive	Paths 13 At scan: classes/CommunityService.cls:458 Submitted source: classes/setup/service/CommunityService.cls:458	See R-012 under “Apex CRUD Violation” — same code location, same response.

Reported vulnerability	Location	Response
R-062 Apex SOQL SOSL USER MODE MISSING False positive	Paths 14 At scan: classes/CommunityService.cls:517 Submitted source: classes/setup/service/CommunityService.cls:517	This read-only check verifies that the site guest user has read/create on User External Credential, a standard-object grant the admin must add by hand because a 2GP permission set cannot carry it. The method returns only a boolean for the setup console checklist. The guest user Id is derived on the server, the read never runs as or for a guest request, and failures degrade to a 'check manually' message. The reads are setup data governed by View Setup and Configuration, so they stay in system mode; since the scan each carries its own SYSTEM_MODE comment. • HEAD CommunityService.cls:551-568 - per-site // SYSTEM_MODE: comment directly above the query (setup data about the site GUEST user; only a Boolean / Set<Id> leaves the method) • python3 scripts/lint/system-mode-inventory.py -> 0 unjustified sites • SetupController.cls saveExperienceSite / checkGuestPermissionSet are @AuraEnabled on a with-sharing controller granted only in Fundraising_Admin • docs/security/appexchange-security-review-readiness.md F-1 (third pass, 2026-09-25)
R-063 Apex SOQL SOSL USER MODE MISSING False positive	Paths 15 At scan: classes/CommunityService.cls:552 Submitted source: classes/setup/service/CommunityService.cls:552	This read-only check finds which permission sets grant access to the Stripe external credential's principal, so the setup console can tell the admin whether the guest user can make the payment callout. It returns only permission-set Ids used for an in-memory set intersection, never record data. SetupEntityAccess is a setup object whose visibility is governed by View Setup and Configuration, which the admin permission set does not grant, so the read stays in system mode. The inputs are resolved on the server, the call is reachable only from the admin-only setup controller, and since the scan the site carries its own SYSTEM_MODE comment. • HEAD CommunityService.cls:590-596 - per-site // SYSTEM_MODE: comment directly above the query (setup data about the site GUEST user; only a Boolean / Set<Id> leaves the method) • python3 scripts/lint/system-mode-inventory.py -> 0 unjustified sites • SetupController.cls saveExperienceSite / checkGuestPermissionSet are @AuraEnabled on a with-sharing controller granted only in Fundraising_Admin • docs/security/appexchange-security-review-readiness.md F-1 (third pass, 2026-09-25)

Reported vulnerability	Location	Response
R-064 Apex SOQL SOSL USER MODE MISSING False positive	Paths 16 At scan: classes/CommunityService.cls:357 Submitted source: classes/setup/service/CommunityService.cls:357	This read-only check powers the setup console's 'guest user can read Campaign' step. It reads the guest user's permission-set assignments and counts ObjectPermissions rows granting Campaign read, returning only a boolean so the admin knows whether the documented manual grant is done (a managed package cannot ship that grant on a standard object). No record data leaves the method and the user Id is derived on the server. Both reads are setup data governed by View Setup and Configuration, which the admin permission set does not grant, so they stay in system mode; since the scan each carries its own SYSTEM_MODE comment. • HEAD CommunityService.cls:384-398 - per-site // SYSTEM_MODE: comment directly above the query (setup data about the site GUEST user; only a Boolean / Set<Id> leaves the method) • python3 scripts/lint/system-mode-inventory.py -> 0 unjustified sites • SetupController.cls saveExperienceSite / checkGuestPermissionSet are @AuraEnabled on a with-sharing controller granted only in Fundraising_Admin • docs/security/appexchange-security-review-readiness.md F-1 (third pass, 2026-09-25)
R-028 Apex SOQL SOSL USER MODE MISSING False positive	Paths 17 At scan: classes/SettingsService.cls:676 Submitted source: classes/setup/service/SettingsService.cls:676	See R-028 under “FLS Create” — same code location, same response.
R-065 Apex SOQL SOSL USER MODE MISSING False positive	Paths 20 At scan: classes/FundraiserAdminController_Test.cls:259 Submitted source: classes/campaign/controller/FundraiserAdminController_Test.cls:271	This line is in an @IsTest class (FundraiserAdminController_Test). It seeds the hierarchy custom setting org defaults as test setup before the code under test runs. Test classes cannot be invoked by users at runtime. The flagged statement is a DML fixture write, not a query, and the dataflow source is a picklist describe, not user input. • base/main/default/classes/campaign/controller/FundraiserAdminController_Test.cls:1 - class annotated @isTest(SeeAllData=false) • base/main/default/classes/campaign/controller/FundraiserAdminController_Test.cls:261-271 - setDefaultCampaignType fixture: reads the Campaign.Type picklist describe, then upserts org-default Settings__c as system to seed a test precondition • The flagged line is a DML statement, not SOQL. The "source" is a schema describe. No user input is involved.

Reported vulnerability	Location	Response
R-066 Apex SOQL SOSL USER MODE MISSING False positive	Paths 21 At scan: classes/EventRegistrationController_Test.cls:185 Submitted source: classes/fundraising/controller/EventRegistrationController_Test.cls:185	This line is a test-fixture update inside an @IsTest class. It prepares a ticket product so the controller method under test sees a particular state. It cannot run outside Apex test execution. The dataflow source is a schema describe. - base/main/default/classes/fundraising/controller/EventRegistrationController_Test.cls:1 - class annotated @IsTest(SeeAllData=false) - base/main/default/classes/fundraising/controller/EventRegistrationController_Test.cls:103 - the source is a Product2 record-type describe in a fixture helper - base/main/default/classes/fundraising/controller/EventRegistrationController_Test.cls:185 - fixture update of a test ticket product; DML, not SOQL
R-067 Apex SOQL SOSL USER MODE MISSING False positive	Paths 22 At scan: classes/EventPurchaseService_Test.cls:863 Submitted source: classes/event/service/EventPurchaseService_Test.cls:863	This is a fixture write inside an @IsTest class. It adjusts a test ticket-tier product (for example, sets it sold out or outside its sale window) to arrange the scenario for the service method under test. The class runs only in Apex test execution and is not reachable by any runtime user. The dataflow source is a schema record-type describe, not external input. - base/main/default/classes/event/service/EventPurchaseService_Test.cls:1 - class annotated @IsTest(SeeAllData=false) - base/main/default/classes/event/service/EventPurchaseService_Test.cls:41 - the dataflow source is a Product2 record-type describe inside the makeTicketProduct fixture helper - base/main/default/classes/event/service/EventPurchaseService_Test.cls:863 - fixture mutation of a test ticket tier (capacity, sold count, or window) before the method under test runs; DML, not SOQL
R-068 Apex SOQL SOSL USER MODE MISSING False positive	Paths 23 At scan: classes/EventPurchaseService_Test.cls:280 Submitted source: classes/event/service/EventPurchaseService_Test.cls:280	This is a fixture write inside an @IsTest class. It adjusts a test ticket-tier product (for example, sets it sold out or outside its sale window) to arrange the scenario for the service method under test. The class runs only in Apex test execution and is not reachable by any runtime user. The dataflow source is a schema record-type describe, not external input. - base/main/default/classes/event/service/EventPurchaseService_Test.cls:1 - class annotated @IsTest(SeeAllData=false) - base/main/default/classes/event/service/EventPurchaseService_Test.cls:41 - the dataflow source is a Product2 record-type describe inside the makeTicketProduct fixture helper - base/main/default/classes/event/service/EventPurchaseService_Test.cls:280 - fixture mutation of a test ticket tier (capacity, sold count, or window) before the method under test runs; DML, not SOQL

Reported vulnerability	Location	Response
R-069 Apex SOQL SOSL USER MODE MISSING False positive	Paths 24 At scan: classes/EventPurchaseService_Test.cls:535 Submitted source: classes/event/service/EventPurchaseService_Test.cls:535	This is a fixture write inside an @IsTest class. It adjusts a test ticket-tier product (for example, sets it sold out or outside its sale window) to arrange the scenario for the service method under test. The class runs only in Apex test execution and is not reachable by any runtime user. The dataflow source is a schema record-type describe, not external input. - base/main/default/classes/event/service/EventPurchaseService_Test.cls:1 - class annotated @IsTest(SeeAllData=false) - base/main/default/classes/event/service/EventPurchaseService_Test.cls:41 - the dataflow source is a Product2 record-type describe inside the makeTicketProduct fixture helper - base/main/default/classes/event/service/EventPurchaseService_Test.cls:535 - fixture mutation of a test ticket tier (capacity, sold count, or window) before the method under test runs; DML, not SOQL
R-070 Apex SOQL SOSL USER MODE MISSING False positive	Paths 25 At scan: classes/EventPurchaseService_Test.cls:567 Submitted source: classes/event/service/EventPurchaseService_Test.cls:567	This is a fixture write inside an @IsTest class. It adjusts a test ticket-tier product (for example, sets it sold out or outside its sale window) to arrange the scenario for the service method under test. The class runs only in Apex test execution and is not reachable by any runtime user. The dataflow source is a schema record-type describe, not external input. - base/main/default/classes/event/service/EventPurchaseService_Test.cls:1 - class annotated @IsTest(SeeAllData=false) - base/main/default/classes/event/service/EventPurchaseService_Test.cls:41 - the dataflow source is a Product2 record-type describe inside the makeTicketProduct fixture helper - base/main/default/classes/event/service/EventPurchaseService_Test.cls:567 - fixture mutation of a test ticket tier (capacity, sold count, or window) before the method under test runs; DML, not SOQL
R-071 Apex SOQL SOSL USER MODE MISSING False positive	Paths 26 At scan: classes/EventPurchaseService_Test.cls:598 Submitted source: classes/event/service/EventPurchaseService_Test.cls:598	This is a fixture write inside an @IsTest class. It adjusts a test ticket-tier product (for example, sets it sold out or outside its sale window) to arrange the scenario for the service method under test. The class runs only in Apex test execution and is not reachable by any runtime user. The dataflow source is a schema record-type describe, not external input. - base/main/default/classes/event/service/EventPurchaseService_Test.cls:1 - class annotated @IsTest(SeeAllData=false) - base/main/default/classes/event/service/EventPurchaseService_Test.cls:41 - the dataflow source is a Product2 record-type describe inside the makeTicketProduct fixture helper - base/main/default/classes/event/service/EventPurchaseService_Test.cls:598 - fixture mutation of a test ticket tier (capacity, sold count, or window) before the method under test runs; DML, not SOQL

Reported vulnerability	Location	Response
R-072 Apex SOQL SOSL USER MODE MISSING False positive	Paths 27 At scan: classes/EventPurchaseService_Test.cls:629 Submitted source: classes/event/service/EventPurchaseService_Test.cls:629	This is a fixture write inside an @IsTest class. It adjusts a test ticket-tier product (for example, sets it sold out or outside its sale window) to arrange the scenario for the service method under test. The class runs only in Apex test execution and is not reachable by any runtime user. The dataflow source is a schema record-type describe, not external input. - base/main/default/classes/event/service/EventPurchaseService_Test.cls:1 - class annotated @IsTest(SeeAllData=false) - base/main/default/classes/event/service/EventPurchaseService_Test.cls:41 - the dataflow source is a Product2 record-type describe inside the makeTicketProduct fixture helper - base/main/default/classes/event/service/EventPurchaseService_Test.cls:629 - fixture mutation of a test ticket tier (capacity, sold count, or window) before the method under test runs; DML, not SOQL
R-073 Apex SOQL SOSL USER MODE MISSING False positive	Paths 28–30, 34 At scan: classes/ReceiptSequenceSelector.cls:49 Submitted source: classes/donation/selector/ReceiptSequenceSelector.cls:49	Receipt_Sequence__c is an internal per-tax-year counter row, not donor data. It holds only a year and the last receipt number issued. The query locks the counter (FOR UPDATE) so receipt numbers stay gapless and unique. Access must not depend on the running user, because a user without read access on the counter would otherwise break receipt numbering for their own gift. The only bind is a set of tax years derived from the Opportunity close date; no caller-supplied Id or filter reaches the query, and nothing from the counter row is returned to a UI. - base/main/default/classes/donation/selector/ReceiptSequenceSelector.cls:46-51 - SYSTEM_MODE queryWithBinds, FOR UPDATE, bind is Set<Decimal> of tax years - base/main/default/classes/donation/service/ReceiptNumberService.cls - lockCounters/assignWithoutUnitOfWork are the only callers; class is inherited sharing - base/main/default/classes/donation/domain/Opportunities.cls:249-261 - stampOfflineReceiptNumber (before trigger, with sharing domain) calls assignWithoutUnitOfWork for manually entered Closed Won gifts; this runs as the interactive user, not in batch - base/main/default/objects/Receipt_Sequence__c - sharingModel ReadWrite; Fundraising_Admin CRU+ViewAll, Fundraising_User and ReadOnly Read only (User cannot create a counter, so USER_MODE would break the offline-gift path for staff) - https://developer.salesforce.com/docs/atlas.en-us.apexcode.meta/apexcode/apex_classes_enforce_usermode.htm - USER_MODE with no object access throws a QueryException rather than returning zero rows

Reported vulnerability	Location	Response
R-074 Apex SOQL SOSL USER MODE MISSING False positive	Paths 32 At scan: classes/fplib_QueryFactory.cls:385 Submitted source: classes/fplib/fplib_QueryFactory.cls:385	The flagged line is the fluent return of setCondition() in the open-source FFLib query builder. The class contains no Database.query call; it only assembles a SOQL string. The only execution point on this path is OpportunitiesSelector.selectByContactId, which runs the string with AccessLevel.USER_MODE. The dataflow starts in an @IsTest class. - base/main/default/classes/fplib/fplib_QueryFactory.cls:~375-385 - setCondition stores the condition and returns this; no query executed in the class - base/main/default/classes/donation/selector/OpportunitiesSelector.cls:83-88 - selectByContactId: newQueryFactory().setCondition(...) then Database.queryWithBinds(..., AccessLevel.USER_MODE) - base/main/default/classes/donation/selector/OpportunitiesSelector_Test.cls:131 - source is a test-class query
R-075 Apex SOQL SOSL USER MODE MISSING False positive	Paths 33 At scan: classes/CurrencyResolver.cls:231 Submitted source: classes/shared/CurrencyResolver.cls:231	The query reads only Id and CurrencyIsoCode for parent records whose Ids the trigger-driven rollup already holds, so it can convert gift amounts into the parent's currency before writing the total. The object name comes from the Id's own schema token, not from input, so the dynamic FROM cannot be injected. The result is a map of Id to ISO code that is used in the arithmetic and never returned to a user. Running in user mode would make a rollup fail or mis-convert for a staff user who can save a gift but lacks read FLS on a standard CurrencyIsoCode field. The code catches any exception and falls back to the corporate currency. - base/main/default/classes/shared/CurrencyResolver.cls:225-236 - dynamic FROM built from Id.getSObjectType().getDescribe().getName(); bind is Set<Id>; SYSTEM_MODE; catch returns empty map - base/main/default/classes/shared/CurrencyResolver.cls - isoCodesByRecordId doc states the reason (currency code is not customer data) - base/main/default/classes/donation/selector/OpportunitiesSelector.cls:135 - upstream SYSTEM_MODE rollup read, itself commented

Sharing — 31 paths, 31 locations

Reported vulnerability	Location	Response
R-076 Sharing False positive	Paths 1 At scan: classes/RecurringDonationsSelector.cls:5 Submitted source: classes/recurring/selector/RecurringDonationsSelector.cls:5	inherited sharing is intentional on this selector. It is never the entry point of a transaction, so its record visibility is that of the caller: staff controllers are with sharing, and the guest controllers and reconciliation jobs are without sharing for their own documented reasons. The Apex Developer Guide recommends inherited sharing for 'service classes that must be flexible and support use cases with different sharing modes'. Each query also sets an explicit AccessLevel, and each SYSTEM_MODE query carries its own reason at the call site. - base/main/default/classes/recurring/selector/RecurringDonationsSelector.cls:5 - declaration - base/main/default/classes/shared/Application.cls - resolved via the Selector factory only - grep: no entry-point annotation or async interface in the class

Reported vulnerability	Location	Response
R-077 Sharing False positive	Paths 2 At scan: classes/RecurringDesignationsSelector.cls:1 Submitted source: classes/recurring/selector/RecurringDesignationsSelector.cls:1	inherited sharing is intentional on this selector. It is never the entry point of a transaction, so its record visibility is that of the caller: staff controllers are with sharing, and the guest controllers and reconciliation jobs are without sharing for their own documented reasons. The Apex Developer Guide recommends inherited sharing for 'service classes that must be flexible and support use cases with different sharing modes'. Each query also sets an explicit AccessLevel, and each SYSTEM_MODE query carries its own reason at the call site. - base/main/default/classes/recurring/selector/RecurringDesignationsSelector.cls:1 - declaration - base/main/default/classes/shared/Application.cls - resolved via the Selector factory only - grep: no entry-point annotation or async interface in the class
R-078 Sharing False positive	Paths 3 At scan: classes/PaymentSetupGuideService.cls:82 Submitted source: classes/payment/service/PaymentSetupGuideService.cls:82	This service grades the payment-credential setup for an administrator: Named Credential, External Credential grants and permission-set assignments. It reads setup entities that have no sharing model. It is only reached from the admin settings controller and is never a transaction entry point, so inherited sharing gives it the admin controller's with sharing mode. - base/main/default/classes/payment/service/PaymentSetupGuideService.cls:80-82 - rationale + declaration - base/main/default/permissionsets/Fundraising_Admin.permissionset-meta.xml - SetupController (only set granting it)
R-079 Sharing False positive	Paths 4 At scan: classes/OpportunitiesSelector.cls:12 Submitted source: classes/donation/selector/OpportunitiesSelector.cls:12	inherited sharing is intentional on this selector. It is never the entry point of a transaction, so its record visibility is that of the caller: staff controllers are with sharing, and the guest controllers and reconciliation jobs are without sharing for their own documented reasons. The Apex Developer Guide recommends inherited sharing for 'service classes that must be flexible and support use cases with different sharing modes'. Each query also sets an explicit AccessLevel, and each SYSTEM_MODE query carries its own reason at the call site. - base/main/default/classes/donation/selector/OpportunitiesSelector.cls:12 - declaration - base/main/default/classes/shared/Application.cls - resolved via the Selector factory only - grep: no entry-point annotation or async interface in the class

Reported vulnerability	Location	Response
R-080 Sharing False positive	Paths 5 At scan: classes/fflib_SObjectUnitOfWork.cls:192 Submitted source: classes/fflib/fflib_SObjectUnitOfWork.cls:192	At scan time UserModeDML had no keyword and extended SimpleDML, which is without sharing, so it adopted without sharing. Its DML defaults to AccessLevel.USER_MODE, which re-applies the running user's record sharing and CRUD/FLS whatever the class's own mode, so its default behavior already enforced sharing; only an instance built with an explicit SYSTEM_MODE would have inherited the parent's mode. Since the scan the class declares inherited sharing, so such an instance follows its caller's sharing. No production code constructs UserModeDML; the local change is recorded in the fflib fork log in DEPENDENCIES.md. - HEAD fflib_SObjectUnitOfWork.cls:195-199 - // doc: rationale and public virtual inherited sharing class UserModeDML extends SimpleDML - DEPENDENCIES.md fork log row for fflib_SObjectUnitOfWork.cls UserModeDML - grep: no non-test reference to UserModeDML
R-081 Sharing False positive	Paths 6 At scan: classes/EventTicketTypesSelector.cls:1 Submitted source: classes/event/selector/EventTicketTypesSelector.cls:1	inherited sharing is intentional on this selector. It is never the entry point of a transaction, so its record visibility is that of the caller: staff controllers are with sharing, and the guest controllers and reconciliation jobs are without sharing for their own documented reasons. The Apex Developer Guide recommends inherited sharing for 'service classes that must be flexible and support use cases with different sharing modes'. Each query also sets an explicit AccessLevel, and each SYSTEM_MODE query carries its own reason at the call site. - base/main/default/classes/event/selector/EventTicketTypesSelector.cls:1 - declaration - base/main/default/classes/shared/Application.cls - resolved via the Selector factory only - grep: no entry-point annotation or async interface in the class
R-082 Sharing False positive	Paths 7 At scan: classes/EventRegistrationController.cls:162 Submitted source: classes/fundraising/controller/EventRegistrationController.cls:162	At scan time the inner class had no sharing keyword. It extends GuestAction, which is inherited sharing, so it adopted inherited sharing and, invoked from the without sharing guest controller, ran without sharing. That is required for a guest to create a ticket order against a Campaign it cannot see under sharing; record visibility is decided by explicit predicates (the campaign must be active, published and open for sales). Since the scan the class declares inherited sharing explicitly, so the effective mode is readable at the declaration and unchanged. - HEAD EventRegistrationController.cls:164 - private inherited sharing class CreateTicketIntent extends GuestAction - EventRegistrationController.cls requireOpenCampaign gate (active, published, open for sales) - docs/security/appexchange-security-review-readiness.md F-3

Reported vulnerability	Location	Response
R-083 Sharing False positive	Paths 8 At scan: classes/EmailSenderService.cls:10 Submitted source: classes/setup/service/EmailSenderService.cls:10	This is a stateless helper that stamps the org's configured sender identity onto outbound donor email. It is never a transaction entry point, and it takes the sharing mode of the service that builds the message. It reads only org email configuration. - base/main/default/classes/setup/service/EmailSenderService.cls:1-10 - header + declaration - grep: no entry-point annotation or async interface
R-084 Sharing False positive	Paths 9 At scan: classes/DonationStagingSelector.cls:1 Submitted source: classes/donation/staging/DonationStagingSelector.cls:1	inherited sharing is intentional on this selector. It is never the entry point of a transaction, so its record visibility is that of the caller: staff controllers are with sharing, and the guest controllers and reconciliation jobs are without sharing for their own documented reasons. The Apex Developer Guide recommends inherited sharing for 'service classes that must be flexible and support use cases with different sharing modes'. Each query also sets an explicit AccessLevel, and each SYSTEM_MODE query carries its own reason at the call site. - base/main/default/classes/donation/staging/DonationStagingSelector.cls:1 - declaration - base/main/default/classes/shared/Application.cls - resolved via the Selector factory only - grep: no entry-point annotation or async interface in the class
R-085 Sharing False positive	Paths 10 At scan: classes/DonationService.cls:1 Submitted source: classes/donation/service/DonationService.cls:1	DonationService is never an entry point. Its public methods are reached from the guest donation controllers, where visibility is decided by token or campaign predicates, and from the reconciliation jobs. Both of those callers establish without sharing and document why. When a with sharing staff controller calls it, it runs with sharing. That is the documented behavior of inherited sharing and the reason it is used here. - base/main/default/classes/donation/service/DonationService.cls:1 - declaration - base/main/default/classes/donation/async/StagingReconciliationBatch.cls:182 - finalizeSucceededStaging caller - base/main/default/classes/donation/async/StripePaymentSweep.cls:128 - caller
R-086 Sharing False positive	Paths 11 At scan: classes/DonationMonitorController.cls:63 Submitted source: classes/donation/controller/DonationMonitorController.cls:63	At scan time the inner class had no sharing keyword. It extends ControllerAction, which is inherited sharing, and per the Apex Developer Guide a class with no declaration that extends a parent adopts the parent's sharing mode; the caller is the with sharing outer controller, so the action already ran with sharing. Since the scan the class declares inherited sharing explicitly, which changes no behavior and removes the ambiguity the rule flags. - HEAD DonationMonitorController.cls:65 - private inherited sharing class GetStuckDonations extends ControllerAction - base/main/default/classes/shared/ControllerAction.cls - public abstract inherited sharing class ControllerAction - docs/security/appexchange-security-review-readiness.md F-3 sharing census (re-counted 2026-09-25)

Reported vulnerability	Location	Response
R-087 Sharing False positive	Paths 12 At scan: classes/DonationDesignationsSelector.cls:4 Submitted source: classes/donation/selector/DonationDesignationsSelector.cls:4	inherited sharing is intentional on this selector. It is never the entry point of a transaction, so its record visibility is that of the caller: staff controllers are with sharing, and the guest controllers and reconciliation jobs are without sharing for their own documented reasons. The Apex Developer Guide recommends inherited sharing for 'service classes that must be flexible and support use cases with different sharing modes'. Each query also sets an explicit AccessLevel, and each SYSTEM_MODE query carries its own reason at the call site. - base/main/default/classes/donation/selector/DonationDesignationsSelector.cls:4 - declaration - base/main/default/classes/shared/Application.cls - resolved via the Selector factory only - grep: no entry-point annotation or async interface in the class
R-088 Sharing False positive	Paths 13 At scan: classes/CurrencyResolver.cls:8 Submitted source: classes/shared/CurrencyResolver.cls:8	This helper resolves the currency for a campaign or payment account. It is never a transaction entry point and runs in whatever sharing mode its calling controller established, which is the purpose of inherited sharing. - base/main/default/classes/shared/CurrencyResolver.cls:8 - declaration - grep: no entry-point annotation or async interface
R-089 Sharing False positive	Paths 14 At scan: classes/CampaignMemberSyncService.cls:9 Submitted source: classes/donation/service/CampaignMemberSyncService.cls:9	This is a service, never a transaction entry point. It takes the sharing mode of the controller or job that calls it, which is what inherited sharing is documented for. It has no @AuraEnabled, REST, or async surface of its own. - base/main/default/classes/donation/service/CampaignMemberSyncService.cls:9 - declaration - grep: no entry-point annotation or async interface
R-090 Sharing False positive	Paths 15 At scan: classes/StripePaymentSweep.cls:25 Submitted source: classes/donation/async/StripePaymentSweep.cls:25	The sweep compares Stripe's payment ledger to the org's staging rows and Opportunities, and repairs gaps. That only works if it sees every row. It takes no input from users: the admin 'run now' button starts the same batch with no parameters. - base/main/default/classes/donation/async/StripePaymentSweep.cls:25 - declaration - base/main/default/classes/setup/controller/SetupController.cls:1625 - admin-only executeBatch, no parameters

Reported vulnerability	Location	Response
R-091 Sharing False positive	Paths 16 At scan: classes/StagingReconciliationBatch.cls:28 Submitted source: classes/donation/async/StagingReconciliationBatch.cls:28	The batch has to finalize donation staging rows created by the site guest user, and those rows are not owned by whoever runs the job. The one non-batch entry point is a single-row 'Retry now' action for staff. It re-reads the charge from Stripe and applies the same idempotent outcome logic as the batch. Donation_Staging__c ships with a Public Read/Write internal sharing model, so without sharing gives internal staff no visibility they do not already have. - base/main/default/classes/donation/async/StagingReconciliationBatch.cls:103-112 - reconcileOne: selectById (SYSTEM_MODE) then Stripe retrieve then applyOutcome - base/main/default/classes/donation/controller/DonationMonitorController.cls:173-182 - RetryDonationStagingNow calls reconcileOne(stagingId); only requireNotNull - base/main/default/objects/Donation_Staging__c/Donation_Staging__c.object-meta.xml:11 - <sharingModel>ReadWrite</sharingModel> - base/main/default/permissionsets/Fundraising_User.permissionset-meta.xml - Donation_Staging__c allowRead=true, allowEdit=false
R-092 Sharing False positive	Paths 17 At scan: classes/SettingsService.cls:259 Submitted source: classes/setup/service/SettingsService.cls:259	This private helper copies the package's own static-resource images into public content distributions during install, so the default logo and hero images exist. The install user cannot read StaticResource under sharing. The helper never touches admin- or donor-supplied files, which go through the user-mode upload path. The elevation covers two short methods and nothing else. - base/main/default/classes/setup/service/SettingsService.cls:245-259 - rationale - base/main/default/classes/setup/service/SettingsService.cls:263-268 - StaticResource read by packaged name only - base/main/default/classes/setup/service/SettingsService.cls:107,141 - only instantiation sites
R-093 Sharing False positive	Paths 18 At scan: classes/RetentionPurgeBatch.cls:9 Submitted source: classes/shared/async/RetentionPurgeBatch.cls:9	This batch enforces the configured data-retention policy by deleting expired diagnostic and staging rows. A row hidden from the job's running user by sharing would never be purged, which would defeat the policy. The batch has no entry point other than its scheduler and takes no user input. - base/main/default/classes/shared/async/RetentionPurgeBatch.cls:9 - declaration - base/main/default/classes/shared/async/RetentionPurgeScheduler.cls:20-24 - sole enqueuer
R-094 Sharing False positive	Paths 19 At scan: classes/RefundReconciliationBatch.cls:42 Submitted source: classes/donation/async/RefundReconciliationBatch.cls:42	This is a batch with no public surface beyond the Batchable interface. It reconciles refunds recorded in Stripe against every donation in the org. If it ran with the sharing of the job owner, refunds on records that user cannot see would be silently skipped. No caller can pass it record Ids. - base/main/default/classes/donation/async/RefundReconciliationBatch.cls:42 - declaration - base/main/default/classes/donation/async/RefundReconciliationScheduler.cls:32 - sole enqueuer

Reported vulnerability	Location	Response
R-095 Sharing False positive	Paths 20 At scan: classes/RecurringDonationScheduler.cls:17 Submitted source: classes/recurring/async/RecurringDonationScheduler.cls:17	The scheduler's only work is to start DonorSummaryRollupBatch, the head of the renewal chain, and its only query is a CronTrigger lookup by job name. The batches that read and charge recurring donations declare their own sharing (DonorSummaryRollupBatch is without sharing with its own rationale), and per the Apex Developer Guide a method's sharing mode is set where it is defined, so this class's keyword never reached them. At scan time the class was without sharing with a stale comment; since the scan it is with sharing, with a comment stating that it touches no shared records and that scheduled Apex runs as the user who scheduled it. - HEAD RecurringDonationScheduler.cls:15-19 - // with sharing: rationale and public with sharing class RecurringDonationScheduler implements Schedulable - HEAD RecurringDonationScheduler.cls execute() only calls Database.executeBatch(new DonorSummaryRollupBatch(...)) - base/main/default/classes/donation/async/DonorSummaryRollupBatch.cls - public without sharing class with its own rationale - docs/security/appexchange-security-review-readiness.md F-3
R-096 Sharing False positive	Paths 21 At scan: classes/ReconciliationHeartbeat.cls:10 Submitted source: classes/donation/async/ReconciliationHeartbeat.cls:10	This is a Schedulable with no other entry point. It counts every non-terminal donation staging row in the org and alerts when any is stuck. A sharing-restricted count would depend on who owns the scheduled job, and would under-report. Its only writes are a Transaction_Log__c row and the alert, and nothing is returned to a user. - base/main/default/classes/donation/async/ReconciliationHeartbeat.cls:10 - declaration + rationale - base/main/default/classes/setup/controller/PostInstallHandler.cls:398 - scheduled at install - base/main/default/classes/setup/controller/SetupController.cls:1714 - admin re-schedule (SetupController granted to Fundraising_Admin only)
R-097 Sharing False positive	Paths 22 At scan: classes/PricebookService.cls:25 Submitted source: classes/event/service/PricebookService.cls:25	PricebookService only creates and looks up the package's event price book and its PricebookEntry rows for ticket products. It runs during install, when an admin saves ticket tiers, and during a guest ticket purchase. None of those contexts can rely on the running user's price-book sharing. It handles no donor data, and it only receives Product2 Ids that its callers have read from records they already gated. - base/main/default/classes/event/service/PricebookService.cls:25 - declaration - base/main/default/classes/event/controller/EventTicketAdminController.cls:142-149,226-233 - product Id derived from the saved tier - base/main/default/classes/setup/controller/PostInstallHandler.cls:1515,1555 - install callers

Reported vulnerability	Location	Response
R-098 Sharing False positive	Paths 23 At scan: classes/PostInstallHandler.cls:9 Submitted source: classes/setup/controller/PostInstallHandler.cls:9	This is the package InstallHandler. It seeds settings, themes, record-type mappings, the event price book and content templates, and schedules the package's background jobs. That data is org-wide configuration, which must be created regardless of the install user's sharing. Its public helpers are also re-run from the admin-only Settings console to repair a missing seed or a job owned by a deactivated user. They take no record Ids and are idempotent. - base/main/default/classes/setup/controller/PostInstallHandler.cls:1-9 - rationale - base/main/default/classes/setup/controller/SetupController.cls:505-518 - admin Fix button calls scheduleJobs(true)/seedRecordTypeMappings - base/main/default/classes/setup/controller/SetupController.cls:1500-1512 - saveGeneralSettings re-owns jobs via scheduleJobs(true) - base/main/default/permissionsets/Fundraising_Admin.permissionset-meta.xml - SetupController granted only here
R-099 Sharing False positive	Paths 24 At scan: classes/NpspSyncService.cls:14 Submitted source: classes/donation/service/NpspSyncService.cls:14	This service mirrors finalized donations into the optional NPSP objects (allocations and recurring donations). It runs from system contexts: the finalization platform-event subscriber and the reconciliation jobs that finalize donations. The records it writes belong to another package, and this package's permission sets cannot grant access to them. It never takes a record Id from a user: every Id comes from a donation or schedule the same transaction just finalized. NPSP rejections are logged and swallowed, so they cannot roll back a captured payment. - base/main/default/classes/donation/service/NpspSyncService.cls:1-14 - header + declaration - base/main/default/classes/donation/service/DonationFinalizedSubscriberHandler.cls:18-19 - syncAllocations caller - base/main/default/classes/recurring/service/RecurringDonationService.cls:610-622 - its own doc comment: callers are StagingReconciliationBatch and StripePaymentSweep 'running as their batch owner, NOT the Automated Process user' - base/main/default/classes/donation/service/DonationService.cls:555-557 - completeScheduleActivation from finalizeSucceededStaging - No PlatformEventSubscriberConfig in base/ - the subscriber runs as the default Automated Process user

Reported vulnerability	Location	Response
R-100 Sharing False positive	Paths 25 At scan: <code>classes/GuestRequestService.cls:13</code> Submitted source: <code>classes/guestrequest/service/GuestRequestService.cls:13</code>	This service queues and processes public requests (attendee naming, refund requests) submitted from the donor portal. It is only reached after the portal has authorized the donor, and by the background sweep. The staff methods it also serves read and close requests for a gift. They are gated by the Process_Refunds custom permission, and Guest_Request__c ships with a Public Read/Write internal sharing model, so running without sharing gives staff no visibility they would not already have. - base/main/default/classes/guestrequest/service/GuestRequestService.cls:8-13 - rationale - base/main/default/classes/donation/controller/RefundController.cls:78-88 - staff caller gated by Process_Refunds - base/main/default/objects/Guest_Request__c/Guest_Request__c.object-meta.xml:11 - <code><sharingModel>ReadWrite</sharingModel></code> - base/main/default/classes/donor/service/DonorPortalService.cls:1118,1269 - submit callers
R-101 Sharing False positive	Paths 26 At scan: <code>classes/fflib_SObjectUnitOfWork.cls:139</code> Submitted source: <code>classes/fflib/fflib_SObjectUnitOfWork.cls:139</code>	At scan time SimpleDML, the Unit of Work's default DML strategy, was declared without sharing, so every commit in the package bypassed record-level sharing. Since the scan, fflib_SObjectUnitOfWork and SimpleDML are declared inherited sharing (the declaration upstream fflib accepted in issue #530): a Unit of Work committed from a with sharing controller or service now runs with sharing, and the platform enforces the running user's record access on the write. The guest, batch, platform-event-subscriber and trigger-rollup writes that must bypass sharing opt in explicitly by constructing their Unit of Work with SystemDML, a package-authored without sharing subclass whose four DML statements pin AccessLevel.SYSTEM_MODE and carry the reason; each of the 24 construction sites states which family it belongs to. Object and field permissions are enforced one layer up, in the FFLib Selectors and by Security.stripInaccessible, and staff update/delete paths additionally filter through RecordAccess before registering the write. SystemDML_Test proves, with a Minimum Access user, that the default commit on an unshared row is refused and the SystemDML commit succeeds. - HEAD fflib_SObjectUnitOfWork.cls:64 - <code>public virtual inherited sharing class fflib_SObjectUnitOfWork</code> - HEAD fflib_SObjectUnitOfWork.cls:154 - <code>public inherited sharing virtual class SimpleDML implements IDML, IDMLUpsertable</code>, with the <code>// doc:</code> rationale above it - HEAD base/main/default/classes/shared/SystemDML.cls - <code>public without sharing class SystemDML extends fflib_SObjectUnitOfWork.SimpleDML</code>, rationale and family list at the declaration - grep: <code>new SystemDML()</code> at 24 production sites, each preceded by a <code>// SystemDML: guest job rollup</code> comment; none in a staff controller - base/main/default/classes/shared/SystemDML_Test.cls - Minimum Access user: SimpleDML commit on an unshared Log__c throws, SystemDML commit lands - DEPENDENCIES.md fork log row for fflib_SObjectUnitOfWork.cls :64/:154; docs/security/appexchange-security-review-readiness.md F-10 item 13 and FP-3 family 4 https://github.com/apex-enterprise-patterns/fflib-apex-common/issues/530 - upstream proposal for the same inherited sharing declarations

Reported vulnerability	Location	Response
R-102 Sharing False positive	Paths 27 At scan: classes/EventRegistrationController.cls:4 Submitted source: classes/fundraising/controller/EventRegistrationController.cls:4	This is the public event-registration controller for an Experience Cloud site, and the guest user has no sharing that would expose an event campaign. Every method is narrow. Reads are gated on an active, published campaign resolved by slug or Id. The write is gated on the event being open for sales. The two status methods require the unguessable access token issued at checkout. Errors are sanitized through GuestAction. Staff hold the same class grant, but reach nothing beyond what an anonymous visitor can. - base/main/default/classes/fundraising/controller/EventRegistrationController.cls:15-80 - the five @AuraEnabled methods - base/main/default/classes/fundraising/controller/EventRegistrationController.cls:568-590 - requireActiveCampaign/requireOpenCampaign - base/main/default/classes/fundraising/controller/EventRegistrationController.cls:486-515 - token-gated status/receipt methods - base/main/default/permissionsets/Fundraising_GuestDonor.permissionset-meta.xml:36 - guest grant
R-103 Sharing False positive	Paths 28 At scan: classes/DonorPortalService.cls:45 Submitted source: classes/donor/service/DonorPortalService.cls:45	The class is without sharing so the Experience Cloud guest user, which has no sharing on Contact, Account or Portal_Access_Token__c, can resolve a donor from an access code and mint a portal session; every guest method is authorized by possession of the code or session it produces and trusts no client-supplied record Id. The class also holds two staff methods, issueAccessCodeForDonor and createAccessCodeForDonor, which take a record Id from a Lightning component. At scan time nothing checked that the staff user could see that record. Since the scan, both staff methods re-read the donor in the staff user's mode (USER_MODE selectors, resolveStaffDonorEmail) and refuse a donor the user cannot see before anything is minted or returned, and the class header states that its without sharing must not become a way to reach records outside the caller's access. - HEAD DonorPortalService.cls:38-47 - header rationale for without sharing and the staff-twin exception; :48 declaration - HEAD DonorPortalAdminController.cls:141 / :160 - USER_MODE reads of the Contact / Person Account before the service is called - docs/security/appexchange-security-review-readiness.md F-10; FP-3 sharing census
R-104 Sharing False positive	Paths 29 At scan: classes/CommunityService.cls:8 Submitted source: classes/setup/service/CommunityService.cls:8	CommunityService backs the admin Settings console's Experience Cloud panel. It reads Network, the site guest User, PermissionSetAssignment and BackgroundOperation to tell the admin whether the public site is configured correctly. These are setup entities, and the only caller is the admin-only settings controller. It returns status flags and names only. - base/main/default/classes/setup/service/CommunityService.cls:6-8 - rationale - base/main/default/classes/setup/controller/SetupController.cls:2185-2318 - all call sites - grep: CommunityService referenced only by SetupController, Application and TestDataFactory among non-test classes (others are comments)

Reported vulnerability	Location	Response
R-105 Sharing False positive	Paths 30 At scan: <code>classes/AttendeeNamingHandler.cls:14</code> Submitted source: <code>classes/guestrequest/handler/AttendeeNamingHandler.cls:14</code>	This handler fills in guest names on the seats of one ticket order, for a request the donor submitted through the portal. It runs asynchronously from the request queue, where no sharing relationship to the donor's order exists. The authorization was performed when the request was accepted (portal session or code, then the order Id recorded server-side). The payload is size-capped and parsed defensively. - base/main/default/classes/guestrequest/handler/AttendeeNamingHandler.cls:10-14 - rationale - base/main/default/classes/guestrequest/handler/GuestRequestRouter.cls:19 - sole constructor site - base/main/default/classes/guestrequest/handler/AttendeeNamingHandler.cls:19 - MAX_SEATS cap on untrusted payload
R-106 Sharing False positive	Paths 31 At scan: <code>classes/AppLogger.cls:4</code> Submitted source: <code>classes/shared/AppLogger.cls:4</code>	AppLogger only inserts diagnostic Log__c rows. It performs no queries and returns no records, so there is no data a caller could read through it. It must succeed from any context, including the guest user and failures caused by sharing, or the error being logged is lost. Log__c is read-only to staff and not granted to the guest user. - base/main/default/classes/shared/AppLogger.cls:1-4 - rationale - base/main/default/classes/shared/AppLogger.cls:77 - the only DML: insert as system Log__c

Apex VF Dynamic JS Resource — 2 paths, 2 locations

Reported vulnerability	Location	Response
R-107 Apex VF Dynamic JS Resource False positive	Paths 1 At scan: <code>pages/stripePayment.page:39</code> Submitted source: <code>pages/stripePayment.page:40</code>	This is a static <code><script></code> tag with a literal <code>https://js.stripe.com</code> URL; no merge field, parameter or stored value contributes to the src, so it is not a dynamically constructed resource. Stripe's documentation requires Stripe.js to be loaded directly from <code>https://js.stripe.com</code> and not bundled or self-hosted, so it cannot be moved into a static resource; <code>js.stripe.com</code> is shipped as a packaged CSP Trusted Site. The page exists precisely to keep Stripe.js out of the LWC runtime: the LWC frames this Visualforce page by relative URL and talks to it by <code>postMessage</code>, Stripe Elements tokenizes card data in Stripe's own nested iframe, and only a payment-method id is returned to Apex. The page has no Apex controller and renders no server value into its script: the <code>postMessage</code> peer is the page's own origin (<code>window.location.origin</code>), and inbound messages are accepted only from that origin and from <code>window.parent</code>. - base/main/default/pages/stripePayment.page:48-53 - justification comment + static script tag (line 40 in the 2026-09-16 scan) - base/main/default/pages/stripePayment.page:1-7 - <code><apex:page></code> declares no controller; the page contains no <code>{!...}</code> merge field - base/main/default/pages/stripePayment.page:89 - <code>var PARENT_ORIGIN = window.location.origin</code>; (the page is always framed same-origin) - base/main/default/pages/stripePayment.page:139 - message listener drops any event whose origin <code>!== PARENT_ORIGIN</code> or whose source <code>!== window.parent</code> - base/main/default/pages/stripePayment.page:169-174 - <code>returnUrl</code> built with <code>encodeURIComponent</code> on <code>publishableKey</code> and <code>stagingId</code> - base/main/default/lwc/dfForm/dfForm.js:441 - parent side checks <code>event.origin === ALLOWED_ORIGIN (window.location.origin)</code> <code>https://docs.stripe.com/js/including</code> - 'it should always be loaded directly from <code>https://js.stripe.com</code>, rather than included in a bundle or hosted yourself' <code>https://docs.stripe.com/security/guide</code> - Stripe.js CSP directives: <code>script-src https://*.js.stripe.com, https://js.stripe.com; frame-src https://*.js.stripe.com, https://js.stripe.com, https://hooks.stripe.com; connect-src https://api.stripe.com</code> - base/main/default/cspTrustedSites/Stripe_js.cspTrustedSite-meta.xml - <code>endpointUrl https://js.stripe.com</code>, <code>isActive true</code>, <code>connect-src + frame-src</code>, <code>context All</code> (CspTrustedSite metadata has no <code>script-src</code> flag) - base/main/default/cspTrustedSites/ - also <code>Stripe_api (api.stripe.com)</code>, <code>Stripe_hooks (hooks.stripe.com)</code>, <code>Stripe_m</code>, <code>Stripe_m_network</code>; no <code>*.js.stripe.com</code> entry (Stripe lists it as optional, for performance)

Reported vulnerability	Location	Response
R-108 Apex VF Dynamic JS Resource False positive	Paths 2 At scan: pages/stripePaymentReturn.page:27 Submitted source: pages/stripePaymentReturn.page:28	This is a static <script> tag with a literal https://js.stripe.com URL, the second of the two Stripe.js loads in the package; nothing dynamic contributes to the src. Stripe redirects the donor here after an off-site authentication step (3D Secure, bank redirect), and the page needs Stripe.js to call retrievePaymentIntent/retrieveSetupIntent; Stripe's documentation requires Stripe.js to be loaded from js.stripe.com rather than self-hosted, which is why it is not a static resource. URL parameters read by the page (pk and the Stripe intent client secret) are passed only to Stripe.js calls, and status text is written with textContent. The page has no Apex controller. Its only server-rendered value is the 'Return to the site' link, whose href is the org's saved Experience site URL read through a \$Setup merge field, rendered only when it begins with https://, and never taken from the query string. - base/main/default/pages/stripePaymentReturn.page:35-40 - justification comment + static script tag (line 28 in the 2026-09-16 scan) - base/main/default/pages/stripePaymentReturn.page:1-7 - <apex:page> declares no controller - base/main/default/pages/stripePaymentReturn.page:82-87 - only merge fields: the return link, rendered only when \$Setup.Settings__c.Experience_Site_URL__c BEGINS 'https://', value from the same setting (never from a URL parameter) - base/main/default/pages/stripePaymentReturn.page:91-96 - pk and intent client secrets read from URLSearchParams; pk only passed to Stripe(pk); the opp parameter is never read - base/main/default/pages/stripePaymentReturn.page:109-113 - PARENT_ORIGIN = window.location.origin; postMessage targets only that origin - base/main/default/pages/stripePaymentReturn.page:119-123 - showStatus writes title/message/icon via textContent - https://docs.stripe.com/js/including - 'it should always be loaded directly from https://js.stripe.com, rather than included in a bundle or hosted yourself' - https://docs.stripe.com/security/guide - Stripe.js CSP directives: script-src https://*.js.stripe.com, https://js.stripe.com; frame-src https://*.js.stripe.com, https://js.stripe.com, https://hooks.stripe.com; connect-src https://api.stripe.com - base/main/default/cspTrustedSites/Stripe_js.cspTrustedSite-meta.xml - endpointUrl https://js.stripe.com, isActive true, connect-src + frame-src, context All (CspTrustedSite metadata has no script-src flag) - base/main/default/cspTrustedSites/ - also Stripe_api (api.stripe.com), Stripe_hooks (hooks.stripe.com), Stripe_m, Stripe_m_network; no *.js.stripe.com entry (Stripe lists it as optional, for performance)

Appendix A — every reported path

Query	Path	Source (scan)	Sink (scan)	Response	Status
Apex CRUD Violation	1	classes/fflib_QueryFactory.cls:383	classes/PaymentSetupGuideService.cls:1753	R-001	False positive
Apex CRUD Violation	2	classes/fflib_QueryFactory.cls:383	classes/ReceiptService.cls:501	R-002	False positive
Apex CRUD Violation	3	classes/fflib_QueryFactory.cls:383	classes/ReceiptService.cls:49	R-003	False positive
Apex CRUD Violation	4	classes/fflib_QueryFactory.cls:383	classes/RefundRequestHandler.cls:124	R-004	False positive
Apex CRUD Violation	5	classes/fflib_QueryFactory.cls:383	classes/ReceiptService.cls:614	R-005	False positive
Apex CRUD Violation	6	classes/fflib_QueryFactory.cls:383	classes/ReceiptService.cls:111	R-006	False positive
Apex CRUD Violation	7	classes/fflib_QueryFactory.cls:383	classes/ReceiptService.cls:91	R-007	False positive
Apex CRUD Violation	8	classes/fflib_QueryFactory.cls:383	classes/ReceiptService.cls:420	R-008	False positive
Apex CRUD Violation	9	classes/fflib_IDGenerator.cls:37	classes/PaymentSetupGuideService.cls:1753	R-001	False positive
Apex CRUD Violation	10	classes/fflib_IDGenerator.cls:37	classes/ReceiptService.cls:420	R-008	False positive
Apex CRUD Violation	11	classes/fflib_IDGenerator.cls:37	classes/ReceiptService.cls:264	R-009	False positive
Apex CRUD Violation	12	classes/fflib_IDGenerator.cls:37	classes/DonorPortalService.cls:411	R-010	False positive
Apex CRUD Violation	13	classes/fflib_IDGenerator.cls:37	classes/DonorPortalService.cls:469	R-011	False positive
Apex CRUD Violation	14	classes/fflib_IDGenerator.cls:37	classes/ReceiptService.cls:501	R-002	False positive
Apex CRUD Violation	15	classes/SetupController.cls:226	classes/PaymentSetupGuideService.cls:1753	R-001	False positive
Apex CRUD Violation	16	classes/SetupController.cls:325	classes/CommunityService.cls:458	R-012	False positive
Apex CRUD Violation	17	classes/fflib_QueryFactory.cls:255	classes/RefundRequestHandler.cls:124	R-004	False positive
Apex CRUD Violation	18	classes/fflib_QueryFactory.cls:255	classes/ReceiptService.cls:420	R-008	False positive
Apex CRUD Violation	19	classes/DonationMonitorController.cls:32	classes/ReceiptService.cls:49	R-003	False positive
Apex CRUD Violation	20	classes/fflib_ApexMocks.cls:69	classes/ReceiptService.cls:335	R-013	False positive
Apex CRUD Violation	21	classes/fflib_ApexMocks.cls:69	classes/ReceiptService.cls:264	R-009	False positive
Apex CRUD Violation	22	classes/DonorPortalAdminController.cls:27	classes/DonorPortalService.cls:411	R-010	False positive
Apex CRUD Violation	23	classes/DonorPortalAdminController.cls:27	classes/DonorPortalService.cls:469	R-011	False positive
Apex CRUD Violation	24	classes/DonorPortalAdminController.cls:32	classes/DonorPortalService.cls:411	R-010	False positive
Apex CRUD Violation	25	classes/DonorPortalAdminController.cls:32	classes/DonorPortalService.cls:469	R-011	False positive
Apex CRUD Violation	26	classes/fflib_QueryFactory.cls:286	classes/ReceiptService.cls:420	R-008	False positive
Apex CRUD Violation	27	classes/fflib_QueryFactory.cls:286	classes/RefundRequestHandler.cls:124	R-004	False positive
Apex CRUD Violation	28	classes/ReceiptAdminController.cls:26	classes/ReceiptService.cls:111	R-006	False positive
Apex CRUD Violation	29	classes/fflib_QueryFactory.cls:266	classes/ReceiptService.cls:614	R-005	False positive
Apex CRUD Violation	30	classes/fflib_QueryFactory.cls:611	classes/ReceiptService.cls:614	R-005	False positive

Query	Path	Source (scan)	Sink (scan)	Response	Status
Apex CRUD Violation	31	classes/fplib_QueryFactory.cls:611	classes/ReceiptService.cls:111	R-006	False positive
Apex CRUD Violation	32	classes/fplib_ApexMocks.cls:115	classes/ReceiptService.cls:335	R-013	False positive
Apex CRUD Violation	33	classes/fplib_ApexMocks.cls:115	classes/ReceiptService.cls:264	R-009	False positive
Apex CRUD Violation	34	classes/RefundController.cls:10	classes/ReceiptService.cls:335	R-013	False positive
Apex CRUD ContentDistribution	1	classes/CampaignPostService.cls:378	classes/CampaignPostService.cls:392	R-014	False positive
Apex CRUD ContentDistribution	2	classes/TestDataFactory.cls:422	classes/TestDataFactory.cls:430	R-015	False positive
Apex CRUD ContentDistribution	3	classes/TestDataFactory.cls:422	classes/TestDataFactory.cls:436	R-016	False positive
Apex CRUD ContentDistribution	4	classes/CampaignPostService.cls:381	classes/CampaignPostService.cls:392	R-014	False positive
Apex CRUD ContentDistribution	5	classes/SettingsService.cls:287	classes/SettingsService.cls:73	R-017	False positive
Apex CRUD ContentDistribution	6	classes/SettingsService.cls:332	classes/SettingsService.cls:73	R-017	False positive
Apex CRUD ContentDistribution	7	classes/SettingsService.cls:346	classes/EventTicketAdminController_Test.cls:484	R-018	False positive
Client DOM Stored XSS	1	lwc/publicDonorDashboard/publicDonorDashboard.js:305	lwc/pfGivingStatement/pfGivingStatement.html:34	R-019	False positive
CRUD Delete	1	classes/fplib_SObjectUnitOfWork.cls:217	classes/fplib_SObjectUnitOfWork.cls:217	R-020	False positive
CRUD Delete	2	classes/RetentionPurgeBatch.cls:66	classes/RetentionPurgeBatch.cls:66	R-021	False positive
FLS Create	1	classes/ReconciliationHeartbeat.cls:24	classes/ReconciliationHeartbeat.cls:23	R-022	False positive
FLS Create	2	classes/AppLogger.cls:78	classes/AppLogger.cls:77	R-023	False positive
FLS Create	3	classes/AppLogger.cls:79	classes/AppLogger.cls:77	R-023	False positive
FLS Create	4	classes/AppLogger.cls:80	classes/AppLogger.cls:77	R-023	False positive
FLS Create	5	classes/AppLogger.cls:81	classes/AppLogger.cls:77	R-023	False positive
FLS Create	6	classes/AppLogger.cls:82	classes/AppLogger.cls:77	R-023	False positive
FLS Create	7	classes/AppLogger.cls:83	classes/AppLogger.cls:77	R-023	False positive
FLS Create	8	classes/StripePaymentSweep.cls:164	classes/StripePaymentSweep.cls:163	R-024	False positive
FLS Create	9	classes/StripePaymentSweep.cls:165	classes/StripePaymentSweep.cls:163	R-024	False positive
FLS Create	10	classes/StripePaymentSweep.cls:166	classes/StripePaymentSweep.cls:163	R-024	False positive
FLS Create	11	classes/StripePaymentSweep.cls:167	classes/StripePaymentSweep.cls:163	R-024	False positive
FLS Create	12	classes/StripePaymentSweep.cls:168	classes/StripePaymentSweep.cls:163	R-024	False positive
FLS Create	13	classes/SettingsService.cls:63	classes/SettingsService.cls:73	R-017	False positive
FLS Create	14	classes/PostInstallHandler.cls:126	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	15	classes/PostInstallHandler.cls:127	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	16	classes/PostInstallHandler.cls:128	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	17	classes/PostInstallHandler.cls:129	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	18	classes/PostInstallHandler.cls:130	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	19	classes/PostInstallHandler.cls:131	classes/PostInstallHandler.cls:170	R-025	False positive

Query	Path	Source (scan)	Sink (scan)	Response	Status
FLS Create	20	classes/PostInstallHandler.cls:132	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	21	classes/PostInstallHandler.cls:133	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	22	classes/PostInstallHandler.cls:134	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	23	classes/PostInstallHandler.cls:135	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	24	classes/PostInstallHandler.cls:136	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	25	classes/PostInstallHandler.cls:137	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	26	classes/PostInstallHandler.cls:138	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	27	classes/PostInstallHandler.cls:139	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	28	classes/PostInstallHandler.cls:142	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	29	classes/PostInstallHandler.cls:143	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	30	classes/PostInstallHandler.cls:144	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	31	classes/PostInstallHandler.cls:145	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	32	classes/PostInstallHandler.cls:146	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	33	classes/PostInstallHandler.cls:151	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	34	classes/PostInstallHandler.cls:157	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	35	classes/PostInstallHandler.cls:162	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	36	classes/PostInstallHandler.cls:165	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	37	classes/StagingReconciliationBatch.cls:180	classes/StagingReconciliationBatch.cls:239	R-026	False positive
FLS Create	38	classes/StagingReconciliationBatch.cls:212	classes/StagingReconciliationBatch.cls:239	R-026	False positive
FLS Create	39	classes/RefundReconciliationBatch.cls:530	classes/RefundReconciliationBatch.cls:532	R-027	False positive
FLS Create	40	classes/RefundReconciliationBatch.cls:531	classes/RefundReconciliationBatch.cls:532	R-027	False positive
FLS Create	41	classes/SettingsService.cls:668	classes/SettingsService.cls:676	R-028	False positive
FLS Create	42	classes/SettingsService.cls:670	classes/SettingsService.cls:676	R-028	False positive
FLS Create	43	classes/PostInstallHandler.cls:1487	classes/PostInstallHandler.cls:1488	R-029	False positive
FLS Create	44	classes/PostInstallHandler.cls:1525	classes/PostInstallHandler.cls:1526	R-030	False positive
FLS Create	45	classes/PostInstallHandler.cls:1565	classes/PostInstallHandler.cls:1566	R-031	False positive
FLS Create	46	classes/SettingsService.cls:60	classes/SettingsService.cls:73	R-017	False positive
FLS Create	47	classes/PostInstallHandler.cls:112	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	48	classes/PostInstallHandler.cls:113	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	49	classes/PostInstallHandler.cls:114	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	50	classes/PostInstallHandler.cls:120	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Create	51	classes/StagingReconciliationBatch.cls:179	classes/StagingReconciliationBatch.cls:239	R-026	False positive
FLS Create	52	classes/SettingsService.cls:274	classes/SettingsService.cls:279	R-032	False positive

Query	Path	Source (scan)	Sink (scan)	Response	Status
FLS Create	53	classes/SettingsService.cls:275	classes/SettingsService.cls:279	R-032	False positive
FLS Create	54	classes/SettingsService.cls:276	classes/SettingsService.cls:279	R-032	False positive
FLS Create	55	classes/SettingsService.cls:288	classes/SettingsService.cls:297	R-033	False positive
FLS Create	56	classes/SettingsService.cls:289	classes/SettingsService.cls:297	R-033	False positive
FLS Create	57	classes/SettingsService.cls:290	classes/SettingsService.cls:297	R-033	False positive
FLS Create	58	classes/SettingsService.cls:291	classes/SettingsService.cls:297	R-033	False positive
FLS Create	59	classes/SettingsService.cls:292	classes/SettingsService.cls:297	R-033	False positive
FLS Create	60	classes/PostInstallHandler.cls:1477	classes/PostInstallHandler.cls:1478	R-034	False positive
FLS Create	61	classes/PostInstallHandler.cls:1507	classes/PostInstallHandler.cls:1508	R-035	False positive
FLS Create	62	classes/PostInstallHandler.cls:1547	classes/PostInstallHandler.cls:1548	R-036	False positive
FLS Create	63	classes/StagingReconciliationBatch.cls:178	classes/StagingReconciliationBatch.cls:239	R-026	False positive
FLS Create	64	classes/EventPurchaseService.cls:657	classes/EventPurchaseService.cls:659	R-037	False positive
FLS Create	65	classes/SettingsService.cls:665	classes/SettingsService.cls:676	R-028	False positive
FLS Create	66	classes/PostInstallHandler.cls:1484	classes/PostInstallHandler.cls:1488	R-029	False positive
FLS Create	67	classes/PostInstallHandler.cls:1522	classes/PostInstallHandler.cls:1526	R-030	False positive
FLS Create	68	classes/PostInstallHandler.cls:1562	classes/PostInstallHandler.cls:1566	R-031	False positive
FLS Create	69	classes/CampaignMemberSyncService.cls:64	classes/CampaignMemberSyncService.cls:76	R-038	False positive
FLS Create	70	classes/SettingsService.cls:80	classes/SettingsService.cls:73	R-017	False positive
FLS Create	71	classes/SettingsService.cls:112	classes/SettingsService.cls:73	R-017	False positive
FLS Create	72	classes/SettingsService.cls:120	classes/SettingsService.cls:73	R-017	False positive
FLS Create	73	classes/SettingsService.cls:147	classes/SettingsService.cls:73	R-017	False positive
FLS Create	74	classes/SettingsService.cls:156	classes/SettingsService.cls:73	R-017	False positive
FLS Create	75	classes/StagingReconciliationBatch.cls:160	classes/StagingReconciliationBatch.cls:239	R-026	False positive
FLS Create	76	classes/StagingReconciliationBatch.cls:161	classes/StagingReconciliationBatch.cls:239	R-026	False positive
FLS Create	77	classes/CampaignPostService.cls:383	classes/CampaignPostService.cls:392	R-014	False positive
FLS Create	78	classes/CampaignPostService.cls:384	classes/CampaignPostService.cls:392	R-014	False positive
FLS Create	79	classes/CampaignPostService.cls:385	classes/CampaignPostService.cls:392	R-014	False positive
FLS Create	80	classes/CampaignPostService.cls:386	classes/CampaignPostService.cls:392	R-014	False positive
FLS Create	81	classes/SetupController.cls:1312	classes/SettingsService.cls:73	R-017	False positive
FLS Create	82	classes/SetupController.cls:1316	classes/SettingsService.cls:73	R-017	False positive
FLS Create	83	classes/SetupController.cls:1320	classes/SettingsService.cls:73	R-017	False positive
FLS Create	84	classes/SetupController.cls:1322	classes/SettingsService.cls:73	R-017	False positive
FLS Create	85	classes/SetupController.cls:1324	classes/SettingsService.cls:73	R-017	False positive

Query	Path	Source (scan)	Sink (scan)	Response	Status
FLS Create	86	classes/SetupController.cls:1325	classes/SettingsService.cls:73	R-017	False positive
FLS Create	87	classes/SetupController.cls:1326	classes/SettingsService.cls:73	R-017	False positive
FLS Create	88	classes/SetupController.cls:1327	classes/SettingsService.cls:73	R-017	False positive
FLS Create	89	classes/SetupController.cls:1328	classes/SettingsService.cls:73	R-017	False positive
FLS Create	90	classes/SetupController.cls:1333	classes/SettingsService.cls:73	R-017	False positive
FLS Create	91	classes/SetupController.cls:1337	classes/SettingsService.cls:73	R-017	False positive
FLS Create	92	classes/SetupController.cls:1339	classes/SettingsService.cls:73	R-017	False positive
FLS Create	93	classes/SetupController.cls:1340	classes/SettingsService.cls:73	R-017	False positive
FLS Create	94	classes/SetupController.cls:1341	classes/SettingsService.cls:73	R-017	False positive
FLS Create	95	classes/SetupController.cls:1342	classes/SettingsService.cls:73	R-017	False positive
FLS Create	96	classes/SetupController.cls:1343	classes/SettingsService.cls:73	R-017	False positive
FLS Create	97	classes/SetupController.cls:1344	classes/SettingsService.cls:73	R-017	False positive
FLS Create	98	classes/SetupController.cls:1345	classes/SettingsService.cls:73	R-017	False positive
FLS Create	99	classes/SetupController.cls:1348	classes/SettingsService.cls:73	R-017	False positive
FLS Create	100	classes/SetupController.cls:1352	classes/SettingsService.cls:73	R-017	False positive
FLS Create	101	classes/SetupController.cls:1359	classes/SettingsService.cls:73	R-017	False positive
FLS Create	102	classes/SetupController.cls:1363	classes/SettingsService.cls:73	R-017	False positive
FLS Create	103	classes/SetupController.cls:1367	classes/SettingsService.cls:73	R-017	False positive
FLS Create	104	classes/SetupController.cls:1371	classes/SettingsService.cls:73	R-017	False positive
FLS Create	105	classes/SetupController.cls:1375	classes/SettingsService.cls:73	R-017	False positive
FLS Create	106	classes/SetupController.cls:1379	classes/SettingsService.cls:73	R-017	False positive
FLS Create	107	classes/SetupController.cls:1383	classes/SettingsService.cls:73	R-017	False positive
FLS Create	108	classes/SetupController.cls:1387	classes/SettingsService.cls:73	R-017	False positive
FLS Create	109	classes/SetupController.cls:1391	classes/SettingsService.cls:73	R-017	False positive
FLS Create	110	classes/SetupController.cls:1398	classes/SettingsService.cls:73	R-017	False positive
FLS Create	111	classes/SetupController.cls:1402	classes/SettingsService.cls:73	R-017	False positive
FLS Create	112	classes/SetupController.cls:1407	classes/SettingsService.cls:73	R-017	False positive
FLS Create	113	classes/SetupController.cls:1411	classes/SettingsService.cls:73	R-017	False positive
FLS Create	114	classes/SetupController.cls:1415	classes/SettingsService.cls:73	R-017	False positive
FLS Create	115	classes/SetupController.cls:1419	classes/SettingsService.cls:73	R-017	False positive
FLS Create	116	classes/SetupController.cls:1422	classes/SettingsService.cls:73	R-017	False positive
FLS Create	117	classes/SetupController.cls:1423	classes/SettingsService.cls:73	R-017	False positive
FLS Create	118	classes/SetupController.cls:1425	classes/SettingsService.cls:73	R-017	False positive

Query	Path	Source (scan)	Sink (scan)	Response	Status
FLS Create	119	classes/SetupController.cls:1426	classes/SettingsService.cls:73	R-017	False positive
FLS Create	120	classes/SetupController.cls:1427	classes/SettingsService.cls:73	R-017	False positive
FLS Create	121	classes/SetupController.cls:1432	classes/SettingsService.cls:73	R-017	False positive
FLS Create	122	classes/SetupController.cls:1433	classes/SettingsService.cls:73	R-017	False positive
FLS Create	123	classes/SetupController.cls:1436	classes/SettingsService.cls:73	R-017	False positive
FLS Create	124	classes/SetupController.cls:1437	classes/SettingsService.cls:73	R-017	False positive
FLS Create	125	classes/SetupController.cls:1438	classes/SettingsService.cls:73	R-017	False positive
FLS Create	126	classes/SetupController.cls:1439	classes/SettingsService.cls:73	R-017	False positive
FLS Create	127	classes/SetupController.cls:1440	classes/SettingsService.cls:73	R-017	False positive
FLS Create	128	classes/SetupController.cls:1441	classes/SettingsService.cls:73	R-017	False positive
FLS Create	129	classes/SetupController.cls:1442	classes/SettingsService.cls:73	R-017	False positive
FLS Create	130	classes/SetupController.cls:1443	classes/SettingsService.cls:73	R-017	False positive
FLS Create	131	classes/SetupController.cls:1450	classes/SettingsService.cls:73	R-017	False positive
FLS Create	132	classes/SetupController.cls:1451	classes/SettingsService.cls:73	R-017	False positive
FLS Create	133	classes/SetupController.cls:1452	classes/SettingsService.cls:73	R-017	False positive
FLS Create	134	classes/SetupController.cls:1453	classes/SettingsService.cls:73	R-017	False positive
FLS Create	135	classes/SetupController.cls:1454	classes/SettingsService.cls:73	R-017	False positive
FLS Create	136	classes/SetupController.cls:1455	classes/SettingsService.cls:73	R-017	False positive
FLS Create	137	classes/SetupController.cls:1456	classes/SettingsService.cls:73	R-017	False positive
FLS Create	138	classes/SetupController.cls:1457	classes/SettingsService.cls:73	R-017	False positive
FLS Create	139	classes/SetupController.cls:1458	classes/SettingsService.cls:73	R-017	False positive
FLS Create	140	classes/SetupController.cls:1459	classes/SettingsService.cls:73	R-017	False positive
FLS Create	141	classes/SetupController.cls:1463	classes/SettingsService.cls:73	R-017	False positive
FLS Create	142	classes/SetupController.cls:1464	classes/SettingsService.cls:73	R-017	False positive
FLS Create	143	classes/SetupController.cls:1465	classes/SettingsService.cls:73	R-017	False positive
FLS Create	144	classes/SetupController.cls:1469	classes/SettingsService.cls:73	R-017	False positive
FLS Create	145	classes/SetupController.cls:1472	classes/SettingsService.cls:73	R-017	False positive
FLS Create	146	classes/SetupController.cls:1475	classes/SettingsService.cls:73	R-017	False positive
FLS Create	147	classes/SetupController.cls:1478	classes/SettingsService.cls:73	R-017	False positive
FLS Create	148	classes/SetupController.cls:1481	classes/SettingsService.cls:73	R-017	False positive
FLS Create	149	classes/SetupController.cls:1485	classes/SettingsService.cls:73	R-017	False positive
FLS Create	150	classes/SetupController.cls:1486	classes/SettingsService.cls:73	R-017	False positive
FLS Create	151	classes/SetupController.cls:1487	classes/SettingsService.cls:73	R-017	False positive

Query	Path	Source (scan)	Sink (scan)	Response	Status
FLS Create	152	classes/SetupController.cls:1488	classes/SettingsService.cls:73	R-017	False positive
FLS Create	153	classes/SetupController.cls:1489	classes/SettingsService.cls:73	R-017	False positive
FLS Create	154	classes/SetupController.cls:1490	classes/SettingsService.cls:73	R-017	False positive
FLS Create	155	classes/SetupController.cls:1491	classes/SettingsService.cls:73	R-017	False positive
FLS Create	156	classes/SetupController.cls:1492	classes/SettingsService.cls:73	R-017	False positive
FLS Create	157	classes/SetupController.cls:1493	classes/SettingsService.cls:73	R-017	False positive
FLS Create	158	classes/SetupController.cls:1494	classes/SettingsService.cls:73	R-017	False positive
FLS Create	159	classes/SetupController.cls:1495	classes/SettingsService.cls:73	R-017	False positive
FLS Create	160	classes/PostInstallHandler.cls:1633	classes/PostInstallHandler.cls:1608	R-039	False positive
FLS Create	161	classes/SettingsService.cls:1840	classes/SettingsService.cls:73	R-017	False positive
FLS Create	162	classes/SetupController.cls:2125	classes/SettingsService.cls:73	R-017	False positive
FLS Create	163	classes/SetupController.cls:2220	classes/SettingsService.cls:73	R-017	False positive
FLS Create	164	classes/SettingsService.cls:111	classes/SettingsService.cls:73	R-017	False positive
FLS Create	165	classes/SettingsService.cls:119	classes/SettingsService.cls:73	R-017	False positive
FLS Create	166	classes/PostInstallHandler.cls:1225	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	167	classes/SettingsService.cls:1839	classes/SettingsService.cls:73	R-017	False positive
FLS Create	168	classes/SettingsService.cls:118	classes/SettingsService.cls:73	R-017	False positive
FLS Create	169	classes/PostInstallHandler.cls:1224	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	170	classes/SettingsService.cls:1838	classes/SettingsService.cls:73	R-017	False positive
FLS Create	171	classes/PricebookService.cls:129	classes/PricebookService.cls:83	R-041	False positive
FLS Create	172	classes/PricebookService.cls:129	classes/PricebookService.cls:92	R-042	False positive
FLS Create	173	classes/PricebookService.cls:130	classes/PricebookService.cls:83	R-041	False positive
FLS Create	174	classes/PricebookService.cls:130	classes/PricebookService.cls:92	R-042	False positive
FLS Create	175	classes/PostInstallHandler.cls:1223	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	176	classes/SettingsService.cls:1837	classes/SettingsService.cls:73	R-017	False positive
FLS Create	177	classes/PostInstallHandler.cls:1222	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	178	classes/SettingsService.cls:40	classes/SettingsService.cls:73	R-017	False positive
FLS Create	179	classes/PostInstallHandler.cls:1221	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	180	classes/PostInstallHandler.cls:1623	classes/PostInstallHandler.cls:1608	R-039	False positive
FLS Create	181	classes/PostInstallHandler.cls:1220	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	182	classes/PostInstallHandler.cls:1616	classes/PostInstallHandler.cls:1608	R-039	False positive
FLS Create	183	classes/PostInstallHandler.cls:1617	classes/PostInstallHandler.cls:1608	R-039	False positive
FLS Create	184	classes/PostInstallHandler.cls:1618	classes/PostInstallHandler.cls:1608	R-039	False positive

Query	Path	Source (scan)	Sink (scan)	Response	Status
FLS Create	185	classes/PostInstallHandler.cls:1619	classes/PostInstallHandler.cls:1608	R-039	False positive
FLS Create	186	classes/PostInstallHandler.cls:1620	classes/PostInstallHandler.cls:1608	R-039	False positive
FLS Create	187	classes/PostInstallHandler.cls:1219	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	188	classes/PostInstallHandler.cls:1191	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	189	classes/PostInstallHandler.cls:1187	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	190	classes/PostInstallHandler.cls:1186	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	191	classes/PostInstallHandler.cls:1177	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	192	classes/PostInstallHandler.cls:1176	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	193	classes/PostInstallHandler.cls:1175	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	194	classes/PostInstallHandler.cls:1174	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	195	classes/PostInstallHandler.cls:1173	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	196	classes/PostInstallHandler.cls:1172	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	197	classes/PostInstallHandler.cls:1171	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	198	classes/PostInstallHandler.cls:1170	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	199	classes/PostInstallHandler.cls:1169	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	200	classes/PostInstallHandler.cls:1168	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Create	201	classes/PostInstallHandler.cls:1167	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	1	classes/SettingsService.cls:63	classes/SettingsService.cls:73	R-017	False positive
FLS Update	2	classes/PostInstallHandler.cls:126	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	3	classes/PostInstallHandler.cls:127	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	4	classes/PostInstallHandler.cls:128	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	5	classes/PostInstallHandler.cls:129	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	6	classes/PostInstallHandler.cls:130	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	7	classes/PostInstallHandler.cls:131	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	8	classes/PostInstallHandler.cls:132	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	9	classes/PostInstallHandler.cls:133	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	10	classes/PostInstallHandler.cls:134	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	11	classes/PostInstallHandler.cls:135	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	12	classes/PostInstallHandler.cls:136	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	13	classes/PostInstallHandler.cls:137	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	14	classes/PostInstallHandler.cls:138	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	15	classes/PostInstallHandler.cls:139	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	16	classes/PostInstallHandler.cls:142	classes/PostInstallHandler.cls:170	R-025	False positive

Query	Path	Source (scan)	Sink (scan)	Response	Status
FLS Update	17	classes/PostInstallHandler.cls:143	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	18	classes/PostInstallHandler.cls:144	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	19	classes/PostInstallHandler.cls:145	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	20	classes/PostInstallHandler.cls:146	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	21	classes/PostInstallHandler.cls:151	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	22	classes/PostInstallHandler.cls:157	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	23	classes/PostInstallHandler.cls:162	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	24	classes/PostInstallHandler.cls:165	classes/PostInstallHandler.cls:170	R-025	False positive
FLS Update	25	classes/StagingReconciliationBatch.cls:231	classes/StagingReconciliationBatch.cls:236	R-043	False positive
FLS Update	26	classes/DonorPortalService.cls:302	classes/DonorPortalService.cls:311	R-044	False positive
FLS Update	27	classes/RefundReconciliationBatch.cls:530	classes/RefundReconciliationBatch.cls:532	R-027	False positive
FLS Update	28	classes/RefundReconciliationBatch.cls:531	classes/RefundReconciliationBatch.cls:532	R-027	False positive
FLS Update	29	classes/SettingsService.cls:668	classes/SettingsService.cls:676	R-028	False positive
FLS Update	30	classes/SettingsService.cls:670	classes/SettingsService.cls:676	R-028	False positive
FLS Update	31	classes/PostInstallHandler.cls:1473	classes/PostInstallHandler.cls:1474	R-045	False positive
FLS Update	32	classes/PostInstallHandler.cls:1487	classes/PostInstallHandler.cls:1488	R-029	False positive
FLS Update	33	classes/PostInstallHandler.cls:1525	classes/PostInstallHandler.cls:1526	R-030	False positive
FLS Update	34	classes/PostInstallHandler.cls:1565	classes/PostInstallHandler.cls:1566	R-031	False positive
FLS Update	35	classes/SettingsService.cls:60	classes/SettingsService.cls:73	R-017	False positive
FLS Update	36	classes/SettingsService.cls:80	classes/SettingsService.cls:73	R-017	False positive
FLS Update	37	classes/SettingsService.cls:112	classes/SettingsService.cls:73	R-017	False positive
FLS Update	38	classes/SettingsService.cls:120	classes/SettingsService.cls:73	R-017	False positive
FLS Update	39	classes/SettingsService.cls:147	classes/SettingsService.cls:73	R-017	False positive
FLS Update	40	classes/SettingsService.cls:156	classes/SettingsService.cls:73	R-017	False positive
FLS Update	41	classes/SetupController.cls:1312	classes/SettingsService.cls:73	R-017	False positive
FLS Update	42	classes/SetupController.cls:1316	classes/SettingsService.cls:73	R-017	False positive
FLS Update	43	classes/SetupController.cls:1320	classes/SettingsService.cls:73	R-017	False positive
FLS Update	44	classes/SetupController.cls:1322	classes/SettingsService.cls:73	R-017	False positive
FLS Update	45	classes/SetupController.cls:1324	classes/SettingsService.cls:73	R-017	False positive
FLS Update	46	classes/SetupController.cls:1325	classes/SettingsService.cls:73	R-017	False positive
FLS Update	47	classes/SetupController.cls:1326	classes/SettingsService.cls:73	R-017	False positive
FLS Update	48	classes/SetupController.cls:1327	classes/SettingsService.cls:73	R-017	False positive
FLS Update	49	classes/SetupController.cls:1328	classes/SettingsService.cls:73	R-017	False positive

Query	Path	Source (scan)	Sink (scan)	Response	Status
FLS Update	50	classes/SetupController.cls:1333	classes/SettingsService.cls:73	R-017	False positive
FLS Update	51	classes/SetupController.cls:1337	classes/SettingsService.cls:73	R-017	False positive
FLS Update	52	classes/SetupController.cls:1339	classes/SettingsService.cls:73	R-017	False positive
FLS Update	53	classes/SetupController.cls:1340	classes/SettingsService.cls:73	R-017	False positive
FLS Update	54	classes/SetupController.cls:1341	classes/SettingsService.cls:73	R-017	False positive
FLS Update	55	classes/SetupController.cls:1342	classes/SettingsService.cls:73	R-017	False positive
FLS Update	56	classes/SetupController.cls:1343	classes/SettingsService.cls:73	R-017	False positive
FLS Update	57	classes/SetupController.cls:1344	classes/SettingsService.cls:73	R-017	False positive
FLS Update	58	classes/SetupController.cls:1345	classes/SettingsService.cls:73	R-017	False positive
FLS Update	59	classes/SetupController.cls:1348	classes/SettingsService.cls:73	R-017	False positive
FLS Update	60	classes/SetupController.cls:1352	classes/SettingsService.cls:73	R-017	False positive
FLS Update	61	classes/SetupController.cls:1359	classes/SettingsService.cls:73	R-017	False positive
FLS Update	62	classes/SetupController.cls:1363	classes/SettingsService.cls:73	R-017	False positive
FLS Update	63	classes/SetupController.cls:1367	classes/SettingsService.cls:73	R-017	False positive
FLS Update	64	classes/SetupController.cls:1371	classes/SettingsService.cls:73	R-017	False positive
FLS Update	65	classes/SetupController.cls:1375	classes/SettingsService.cls:73	R-017	False positive
FLS Update	66	classes/SetupController.cls:1379	classes/SettingsService.cls:73	R-017	False positive
FLS Update	67	classes/SetupController.cls:1383	classes/SettingsService.cls:73	R-017	False positive
FLS Update	68	classes/SetupController.cls:1387	classes/SettingsService.cls:73	R-017	False positive
FLS Update	69	classes/SetupController.cls:1391	classes/SettingsService.cls:73	R-017	False positive
FLS Update	70	classes/SetupController.cls:1398	classes/SettingsService.cls:73	R-017	False positive
FLS Update	71	classes/SetupController.cls:1402	classes/SettingsService.cls:73	R-017	False positive
FLS Update	72	classes/SetupController.cls:1407	classes/SettingsService.cls:73	R-017	False positive
FLS Update	73	classes/SetupController.cls:1411	classes/SettingsService.cls:73	R-017	False positive
FLS Update	74	classes/SetupController.cls:1415	classes/SettingsService.cls:73	R-017	False positive
FLS Update	75	classes/SetupController.cls:1419	classes/SettingsService.cls:73	R-017	False positive
FLS Update	76	classes/SetupController.cls:1422	classes/SettingsService.cls:73	R-017	False positive
FLS Update	77	classes/SetupController.cls:1423	classes/SettingsService.cls:73	R-017	False positive
FLS Update	78	classes/SetupController.cls:1425	classes/SettingsService.cls:73	R-017	False positive
FLS Update	79	classes/SetupController.cls:1426	classes/SettingsService.cls:73	R-017	False positive
FLS Update	80	classes/SetupController.cls:1427	classes/SettingsService.cls:73	R-017	False positive
FLS Update	81	classes/SetupController.cls:1432	classes/SettingsService.cls:73	R-017	False positive
FLS Update	82	classes/SetupController.cls:1433	classes/SettingsService.cls:73	R-017	False positive

Query	Path	Source (scan)	Sink (scan)	Response	Status
FLS Update	83	classes/SetupController.cls:1436	classes/SettingsService.cls:73	R-017	False positive
FLS Update	84	classes/SetupController.cls:1437	classes/SettingsService.cls:73	R-017	False positive
FLS Update	85	classes/SetupController.cls:1438	classes/SettingsService.cls:73	R-017	False positive
FLS Update	86	classes/SetupController.cls:1439	classes/SettingsService.cls:73	R-017	False positive
FLS Update	87	classes/SetupController.cls:1440	classes/SettingsService.cls:73	R-017	False positive
FLS Update	88	classes/SetupController.cls:1441	classes/SettingsService.cls:73	R-017	False positive
FLS Update	89	classes/SetupController.cls:1442	classes/SettingsService.cls:73	R-017	False positive
FLS Update	90	classes/SetupController.cls:1443	classes/SettingsService.cls:73	R-017	False positive
FLS Update	91	classes/SetupController.cls:1450	classes/SettingsService.cls:73	R-017	False positive
FLS Update	92	classes/SetupController.cls:1451	classes/SettingsService.cls:73	R-017	False positive
FLS Update	93	classes/SetupController.cls:1452	classes/SettingsService.cls:73	R-017	False positive
FLS Update	94	classes/SetupController.cls:1453	classes/SettingsService.cls:73	R-017	False positive
FLS Update	95	classes/SetupController.cls:1454	classes/SettingsService.cls:73	R-017	False positive
FLS Update	96	classes/SetupController.cls:1455	classes/SettingsService.cls:73	R-017	False positive
FLS Update	97	classes/SetupController.cls:1456	classes/SettingsService.cls:73	R-017	False positive
FLS Update	98	classes/SetupController.cls:1457	classes/SettingsService.cls:73	R-017	False positive
FLS Update	99	classes/SetupController.cls:1458	classes/SettingsService.cls:73	R-017	False positive
FLS Update	100	classes/SetupController.cls:1459	classes/SettingsService.cls:73	R-017	False positive
FLS Update	101	classes/SetupController.cls:1463	classes/SettingsService.cls:73	R-017	False positive
FLS Update	102	classes/SetupController.cls:1464	classes/SettingsService.cls:73	R-017	False positive
FLS Update	103	classes/SetupController.cls:1465	classes/SettingsService.cls:73	R-017	False positive
FLS Update	104	classes/SetupController.cls:1469	classes/SettingsService.cls:73	R-017	False positive
FLS Update	105	classes/SetupController.cls:1472	classes/SettingsService.cls:73	R-017	False positive
FLS Update	106	classes/SetupController.cls:1475	classes/SettingsService.cls:73	R-017	False positive
FLS Update	107	classes/SetupController.cls:1478	classes/SettingsService.cls:73	R-017	False positive
FLS Update	108	classes/SetupController.cls:1481	classes/SettingsService.cls:73	R-017	False positive
FLS Update	109	classes/SetupController.cls:1485	classes/SettingsService.cls:73	R-017	False positive
FLS Update	110	classes/SetupController.cls:1486	classes/SettingsService.cls:73	R-017	False positive
FLS Update	111	classes/SetupController.cls:1487	classes/SettingsService.cls:73	R-017	False positive
FLS Update	112	classes/SetupController.cls:1488	classes/SettingsService.cls:73	R-017	False positive
FLS Update	113	classes/SetupController.cls:1489	classes/SettingsService.cls:73	R-017	False positive
FLS Update	114	classes/SetupController.cls:1490	classes/SettingsService.cls:73	R-017	False positive
FLS Update	115	classes/SetupController.cls:1491	classes/SettingsService.cls:73	R-017	False positive

Query	Path	Source (scan)	Sink (scan)	Response	Status
FLS Update	116	classes/SetupController.cls:1492	classes/SettingsService.cls:73	R-017	False positive
FLS Update	117	classes/SetupController.cls:1493	classes/SettingsService.cls:73	R-017	False positive
FLS Update	118	classes/SetupController.cls:1494	classes/SettingsService.cls:73	R-017	False positive
FLS Update	119	classes/SetupController.cls:1495	classes/SettingsService.cls:73	R-017	False positive
FLS Update	120	classes/SettingsService.cls:1840	classes/SettingsService.cls:73	R-017	False positive
FLS Update	121	classes/SetupController.cls:2125	classes/SettingsService.cls:73	R-017	False positive
FLS Update	122	classes/SetupController.cls:2220	classes/SettingsService.cls:73	R-017	False positive
FLS Update	123	classes/AttendeeNamingHandler.cls:68	classes/AttendeeNamingHandler.cls:91	R-046	False positive
FLS Update	124	classes/AttendeeNamingHandler.cls:76	classes/AttendeeNamingHandler.cls:91	R-046	False positive
FLS Update	125	classes/GuestRequestService.cls:111	classes/GuestRequestService.cls:117	R-047	False positive
FLS Update	126	classes/SettingsService.cls:111	classes/SettingsService.cls:73	R-017	False positive
FLS Update	127	classes/SettingsService.cls:119	classes/SettingsService.cls:73	R-017	False positive
FLS Update	128	classes/GuestRequestService.cls:188	classes/GuestRequestService.cls:196	R-048	False positive
FLS Update	129	classes/PostInstallHandler.cls:309	classes/PostInstallHandler.cls:314	R-049	False positive
FLS Update	130	classes/PostInstallHandler.cls:1225	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	131	classes/SettingsService.cls:1839	classes/SettingsService.cls:73	R-017	False positive
FLS Update	132	classes/AttendeeNamingHandler.cls:67	classes/AttendeeNamingHandler.cls:91	R-046	False positive
FLS Update	133	classes/GuestRequestService.cls:110	classes/GuestRequestService.cls:117	R-047	False positive
FLS Update	134	classes/SettingsService.cls:118	classes/SettingsService.cls:73	R-017	False positive
FLS Update	135	classes/GuestRequestService.cls:187	classes/GuestRequestService.cls:196	R-048	False positive
FLS Update	136	classes/PostInstallHandler.cls:1224	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	137	classes/SettingsService.cls:1838	classes/SettingsService.cls:73	R-017	False positive
FLS Update	138	classes/GuestRequestService.cls:186	classes/GuestRequestService.cls:196	R-048	False positive
FLS Update	139	classes/PostInstallHandler.cls:1223	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	140	classes/SettingsService.cls:1837	classes/SettingsService.cls:73	R-017	False positive
FLS Update	141	classes/PostInstallHandler.cls:1222	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	142	classes/PostInstallHandler.cls:1221	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	143	classes/PostInstallHandler.cls:1220	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	144	classes/PostInstallHandler.cls:1219	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	145	classes/PostInstallHandler.cls:1191	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	146	classes/PostInstallHandler.cls:1187	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	147	classes/PostInstallHandler.cls:1186	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	148	classes/PostInstallHandler.cls:1177	classes/PostInstallHandler.cls:663	R-040	False positive

Query	Path	Source (scan)	Sink (scan)	Response	Status
FLS Update	149	classes/PostInstallHandler.cls:1176	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	150	classes/PostInstallHandler.cls:1175	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	151	classes/PostInstallHandler.cls:1174	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	152	classes/PostInstallHandler.cls:1173	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	153	classes/PostInstallHandler.cls:1172	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	154	classes/PostInstallHandler.cls:1171	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	155	classes/PostInstallHandler.cls:1170	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	156	classes/PostInstallHandler.cls:1169	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	157	classes/PostInstallHandler.cls:1168	classes/PostInstallHandler.cls:663	R-040	False positive
FLS Update	158	classes/PostInstallHandler.cls:1167	classes/PostInstallHandler.cls:663	R-040	False positive
JS Stored XSS	1	lwc/publicCampaignGallery/publicCampaignGallery.js:121	lwc/publicCampaignGallery/publicCampaignGallery.js:125	R-050	Fixed since scan
JS Stored XSS	2	lwc/publicDonorDashboard/publicDonorDashboard.js:437	lwc/publicDonorDashboard/publicDonorDashboard.js:441	R-051	Fixed since scan
JS Stored XSS	3	lwc/publicFundraisingExperience/publicFundraisingExperience.js:377	lwc/publicFundraisingExperience/publicFundraisingExperience.js:381	R-052	Fixed since scan
JS Stored XSS	4	lwc/publicThankYou/publicThankYou.js:153	lwc/publicThankYou/publicThankYou.js:157	R-053	Fixed since scan
Apex SOQL SOSL USER MODE MISSING	1	classes/PostInstallHandler_Test.cls:1550	classes/PostInstallHandler_Test.cls:1553	R-054	False positive
Apex SOQL SOSL USER MODE MISSING	2	classes/PostInstallHandler_Test.cls:1552	classes/PostInstallHandler_Test.cls:1555	R-055	False positive
Apex SOQL SOSL USER MODE MISSING	3	classes/CurrencyResolver.cls:227	classes/CurrencyResolver.cls:232	R-056	False positive
Apex SOQL SOSL USER MODE MISSING	4	classes/FundraiserDetailController.cls:20	classes/AccountsSelector.cls:211	R-057	False positive
Apex SOQL SOSL USER MODE MISSING	5	classes/FundraiserDetailController.cls:20	classes/ContactsSelector.cls:178	R-058	False positive
Apex SOQL SOSL USER MODE MISSING	6	classes/DonorDetailController.cls:32	classes/AccountsSelector.cls:211	R-057	False positive
Apex SOQL SOSL USER MODE MISSING	7	classes/DonorDetailController.cls:32	classes/ContactsSelector.cls:178	R-058	False positive
Apex SOQL SOSL USER MODE MISSING	8	classes/SetupController.cls:320	classes/CommunityService.cls:243	R-059	False positive
Apex SOQL SOSL USER MODE MISSING	9	classes/SetupController.cls:320	classes/SettingsService.cls:73	R-017	False positive

Query	Path	Source (scan)	Sink (scan)	Response	Status
Apex SOQL SOSL USER MODE MISSING	10	classes/GuestRequestController_Test.cls:32	classes/GuestRequestController_Test.cls:76	R-060	False positive
Apex SOQL SOSL USER MODE MISSING	11	classes/SetupController.cls:325	classes/CommunityService.cls:243	R-059	False positive
Apex SOQL SOSL USER MODE MISSING	12	classes/SetupController.cls:325	classes/CommunityService.cls:275	R-061	False positive
Apex SOQL SOSL USER MODE MISSING	13	classes/SetupController.cls:325	classes/CommunityService.cls:458	R-012	False positive
Apex SOQL SOSL USER MODE MISSING	14	classes/SetupController.cls:325	classes/CommunityService.cls:517	R-062	False positive
Apex SOQL SOSL USER MODE MISSING	15	classes/SetupController.cls:325	classes/CommunityService.cls:552	R-063	False positive
Apex SOQL SOSL USER MODE MISSING	16	classes/SetupController.cls:325	classes/CommunityService.cls:357	R-064	False positive
Apex SOQL SOSL USER MODE MISSING	17	classes/SetupController.cls:171	classes/SettingsService.cls:676	R-028	False positive
Apex SOQL SOSL USER MODE MISSING	18	classes/SettingsService.cls:79	classes/SettingsService.cls:73	R-017	False positive
Apex SOQL SOSL USER MODE MISSING	19	classes/SetupController.cls:2117	classes/SettingsService.cls:73	R-017	False positive
Apex SOQL SOSL USER MODE MISSING	20	classes/FundraiserAdminController_Test.cls:249	classes/FundraiserAdminController_Test.cls:259	R-065	False positive
Apex SOQL SOSL USER MODE MISSING	21	classes/EventRegistrationController_Test.cls:103	classes/EventRegistrationController_Test.cls:185	R-066	False positive
Apex SOQL SOSL USER MODE MISSING	22	classes/EventPurchaseService_Test.cls:41	classes/EventPurchaseService_Test.cls:863	R-067	False positive
Apex SOQL SOSL USER MODE MISSING	23	classes/EventPurchaseService_Test.cls:41	classes/EventPurchaseService_Test.cls:280	R-068	False positive
Apex SOQL SOSL USER MODE MISSING	24	classes/EventPurchaseService_Test.cls:41	classes/EventPurchaseService_Test.cls:535	R-069	False positive
Apex SOQL SOSL USER MODE MISSING	25	classes/EventPurchaseService_Test.cls:41	classes/EventPurchaseService_Test.cls:567	R-070	False positive
Apex SOQL SOSL USER MODE MISSING	26	classes/EventPurchaseService_Test.cls:41	classes/EventPurchaseService_Test.cls:598	R-071	False positive
Apex SOQL SOSL USER MODE MISSING	27	classes/EventPurchaseService_Test.cls:41	classes/EventPurchaseService_Test.cls:629	R-072	False positive
Apex SOQL SOSL USER MODE MISSING	28	classes/EventPurchaseService.cls:382	classes/ReceiptSequenceSelector.cls:49	R-073	False positive

Query	Path	Source (scan)	Sink (scan)	Response	Status
Apex SOQL SOSL USER MODE MISSING	29	classes/DonationService.cls:444	classes/ReceiptSequenceSelector.cls:49	R-073	False positive
Apex SOQL SOSL USER MODE MISSING	30	classes/RecurringDonationService.cls:767	classes/ReceiptSequenceSelector.cls:49	R-073	False positive
Apex SOQL SOSL USER MODE MISSING	31	classes/SetupController.cls:132	classes/SettingsService.cls:73	R-017	False positive
Apex SOQL SOSL USER MODE MISSING	32	classes/OpportunitiesSelector_Test.cls:131	classes/fflib_QueryFactory.cls:385	R-074	False positive
Apex SOQL SOSL USER MODE MISSING	33	classes/OpportunitiesSelector.cls:135	classes/CurrencyResolver.cls:231	R-075	False positive
Apex SOQL SOSL USER MODE MISSING	34	classes/RecordTypeService.cls:117	classes/ReceiptSequenceSelector.cls:49	R-073	False positive
Sharing	1	classes/RecurringDonationsSelector.cls:5	classes/RecurringDonationsSelector.cls:5	R-076	False positive
Sharing	2	classes/RecurringDesignationsSelector.cls:1	classes/RecurringDesignationsSelector.cls:1	R-077	False positive
Sharing	3	classes/PaymentSetupGuideService.cls:82	classes/PaymentSetupGuideService.cls:82	R-078	False positive
Sharing	4	classes/OpportunitiesSelector.cls:12	classes/OpportunitiesSelector.cls:12	R-079	False positive
Sharing	5	classes/fflib_SObjectUnitOfWork.cls:192	classes/fflib_SObjectUnitOfWork.cls:192	R-080	False positive
Sharing	6	classes/EventTicketTypesSelector.cls:1	classes/EventTicketTypesSelector.cls:1	R-081	False positive
Sharing	7	classes/EventRegistrationController.cls:162	classes/EventRegistrationController.cls:162	R-082	False positive
Sharing	8	classes/EmailSenderService.cls:10	classes/EmailSenderService.cls:10	R-083	False positive
Sharing	9	classes/DonationStagingSelector.cls:1	classes/DonationStagingSelector.cls:1	R-084	False positive
Sharing	10	classes/DonationService.cls:1	classes/DonationService.cls:1	R-085	False positive
Sharing	11	classes/DonationMonitorController.cls:63	classes/DonationMonitorController.cls:63	R-086	False positive
Sharing	12	classes/DonationDesignationsSelector.cls:4	classes/DonationDesignationsSelector.cls:4	R-087	False positive
Sharing	13	classes/CurrencyResolver.cls:8	classes/CurrencyResolver.cls:8	R-088	False positive
Sharing	14	classes/CampaignMemberSyncService.cls:9	classes/CampaignMemberSyncService.cls:9	R-089	False positive
Sharing	15	classes/StripePaymentSweep.cls:25	classes/StripePaymentSweep.cls:25	R-090	False positive
Sharing	16	classes/StagingReconciliationBatch.cls:28	classes/StagingReconciliationBatch.cls:28	R-091	False positive
Sharing	17	classes/SettingsService.cls:259	classes/SettingsService.cls:259	R-092	False positive
Sharing	18	classes/RetentionPurgeBatch.cls:9	classes/RetentionPurgeBatch.cls:9	R-093	False positive
Sharing	19	classes/RefundReconciliationBatch.cls:42	classes/RefundReconciliationBatch.cls:42	R-094	False positive
Sharing	20	classes/RecurringDonationScheduler.cls:17	classes/RecurringDonationScheduler.cls:17	R-095	False positive
Sharing	21	classes/ReconciliationHeartbeat.cls:10	classes/ReconciliationHeartbeat.cls:10	R-096	False positive
Sharing	22	classes/PricebookService.cls:25	classes/PricebookService.cls:25	R-097	False positive
Sharing	23	classes/PostInstallHandler.cls:9	classes/PostInstallHandler.cls:9	R-098	False positive

Query	Path	Source (scan)	Sink (scan)	Response	Status
Sharing	24	classes/NpsSyncService.cls:14	classes/NpsSyncService.cls:14	R-099	False positive
Sharing	25	classes/GuestRequestService.cls:13	classes/GuestRequestService.cls:13	R-100	False positive
Sharing	26	classes/fflib_SObjectUnitOfWork.cls:139	classes/fflib_SObjectUnitOfWork.cls:139	R-101	False positive
Sharing	27	classes/EventRegistrationController.cls:4	classes/EventRegistrationController.cls:4	R-102	False positive
Sharing	28	classes/DonorPortalService.cls:45	classes/DonorPortalService.cls:45	R-103	False positive
Sharing	29	classes/CommunityService.cls:8	classes/CommunityService.cls:8	R-104	False positive
Sharing	30	classes/AttendeeNamingHandler.cls:14	classes/AttendeeNamingHandler.cls:14	R-105	False positive
Sharing	31	classes/AppLogger.cls:4	classes/AppLogger.cls:4	R-106	False positive
Apex VF Dynamic JS Resource	1	pages/stripePayment.page:39	pages/stripePayment.page:39	R-107	False positive
Apex VF Dynamic JS Resource	2	pages/stripePaymentReturn.page:27	pages/stripePaymentReturn.page:27	R-108	False positive